Combating the “Neuro-Alchemy Chain”

A Threat Modeling and Defense Framework
for Artistic Brain–Computer Interfaces

Junyi He

Master’s Degree Project in
Information Security
Spring term 2026
Supervisor: Johannes Olegård
Department of Computer
and Systems Sciences



Stockholm
University

Abstract

Brain–Computer Interfaces (BCIs) are increasingly deployed in artistic settings, where participants' neural signals are used to generate real-time aesthetic experiences. While such applications are often framed as creative and participatory, they introduce distinctive security and governance challenges. This thesis identifies a novel threat termed "experiential exploitation", where cognitive and affective states are systematically extracted, semantically refined, algorithmically valued, and potentially recirculated across contexts under conditions of immersive engagement and institutional power asymmetry. While existing privacy-enhancing technologies (PETs) and legal frameworks like GDPR provide robust protections against unauthorised data reuse, they cannot prevent exploitation occurring within declared artistic purposes through semantic deepening, hidden comparative valuation, or longitudinal profiling.

To systematically identify the neuro-alchemy chain across the neural data lifecycle, this thesis develops the five-stage Experiential Exploitation Kill Chain (EEKC) and extends STRIDE with an additional experiential threat category (STRIDE-E). The Counter-Alchemy Framework is designed around three defensive layers: source capability minimisation through a Neural Obfuscation Circuit (NOC); semantic integrity protection via Experience-Binding Hash (EBH) and Context-aware Access Control (CAAC); and governance mechanisms implementing non-monetary accountability with a participant-initiated reverse-clearance protocol. The framework is validated through proof-of-concept Python prototypes, privacy-utility tradeoff experiments on public EEG datasets, and a scenario-based walkthrough illustrating how the framework constrains exploitation pathways across EEKC stages.

Guided by Design Science Research (DSR) methodology, this thesis contributes a novel threat model for artistic BCIs and a multi-layered technical architecture aimed at preserving contextual integrity and participant

agency in neuro-artistic practice, offering guidance for artists, institutions, and policymakers concerned with the ethical deployment of artistic BCIs.

Keywords: Brain-Computer Interfaces, Experiential Exploitation, Contextual Integrity, Neural Data Security

Acknowledgements

First and foremost, I would like to express my heartfelt gratitude to my parents for their unconditional support and respect. Special thanks to my mother, who has always stood by my side as my strongest ally through thick and thin.

Furthermore, I would like to extend my sincere appreciation to my supervisor, Johannes Olegård, for his insightful advice and generous guidance throughout this project.

My thanks also go to the scholars whose pioneering work served as a cornerstone for this research and continuously inspired my academic pursuits.

The past two years have been an unforgettable journey. I am deeply grateful to all my teachers and friends for their guidance and companionship.

I wish everyone all the best.

List of Abbreviations

Abbreviation	Full Form
AEFS	Actual Extracted Feature Set
AI	Artificial Intelligence
BCI	Brain-Computer Interface
CAAC	Context-aware Access Control
CIA	Confidentiality-Integrity-Availability (triad)
CT	Context Token (SHA-256 hash of the MNFS declaration)
DEAP	Database for Emotion Analysis using Physiological Signals
DFD	Data Flow Diagram
DP	Differential Privacy
DS1–DS3	Data Stores 1–3 (Raw Signal Store, Feature Store, Neural Archive)
DSR	Design Science Research
DSRM	Design Science Research Methodology
E_1	Experiential Exploitation (STRIDE-E seventh category)
E_2	Elevation of Privilege (STRIDE, as inherited in STRIDE-E)
EBH	Experience-Binding Hash
EEG	Electroencephalography
EEKC	Experiential Exploitation Kill Chain
EU	European Union
EUF-CMA	Existential Unforgeability under Chosen-Message Attacks
FL	Federated Learning
GDPR	General Data Protection Regulation (EU 2016/679)

Abbreviation	Full Form
HCI	Human-Computer Interaction
HMAC	Hash-based Message Authentication Code
ICA	Independent Component Analysis
IRB	Institutional Review Board
MNFS	Minimum Necessary Feature Set
MoSCoW	Must-have, Should-have, Could-have, Won't-have (prioritisation method)
NDUR	Neural Data Use Report
NMAP	Non-Monetary Accountability Protocol
NOC	Neural Obfuscation Circuit
nMSE	Normalised Mean Squared Error
OER	Over-Extraction Ratio ($\lvert \text{AEFS} \setminus \text{MNFS} \rvert / \lvert \text{MNFS} \rvert$)
P1–P6	Processing Elements 1–6 (Signal Acquisition through Secondary Processing)
PD	Purpose Declaration
PDC	Policy Decision Component
PETs	Privacy-Enhancing Technologies
PSD	Power Spectral Density
RCP	Reverse-Clearance Protocol
SDM	Semantic Drift Monitor
SHA-256	Secure Hash Algorithm (256-bit)
SVM	Support Vector Machine
STRIDE	Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege
STRIDE-E	STRIDE extended with the Experiential Exploitation category (E_1)
ε	Differential privacy budget parameter

List of Figures

4.1 Data Flow Diagram for a representative artistic BCI installation. 21
4.2 The Experiential Exploitation Kill Chain (EEKC): five-stage model of authorisation-preserving exploitation. 24

5.1 Counter-Alchemy Framework: three-layer architecture for authorisation-preserving exploitation defence. 30
5.2 CAAC policy decision flow. Unmatched requests are denied by the default-deny posture (R15); all decisions are logged to the append-only audit log. 32

6.1 GAMEEMO privacy-utility tradeoff (G1 calm vs. G3 fear). *Left:* arousal classification accuracy under each obfuscation condition. *Right:* normalised MSE between processed and clean MNFS features. 42
6.2 SEED-IV cross-session re-identification accuracy under each obfuscation condition. Dashed: AEFS baseline (0.567). Dotted: band suppression only (0.172). Orange: MNFS + DP combined. Red dash-dot: chance level (0.067). 43

List of Tables

2.1 BCI-specific security research and shared limitation. 10

4.1 Threat model scope and assumptions. 20
4.2 STRIDE-E × EEKC Cross-Mapping Matrix. E_1 = Experiential Exploitation (novel seventh category); E_2 = Elevation of Privilege. Em-dashes indicate non-characteristic intersections. . 25
4.3 MoSCoW prioritisation of Counter-Alchemy Framework design requirements. 28

6.1 Selected EBH prototype test results. 38
6.2 CAAC policy enforcement test results. 39
6.3 Scenario walkthrough summary: exploitation interruption at each EEKC stage. 44
6.4 Regulatory correspondence mapping of Counter-Alchemy Framework mechanisms to GDPR principles and EU AI Act obligations. 45

A.1 Complete CAAC reference policy set (15 rules). Rules are evaluated in order; first match wins. ALLOW = operation permitted; DENY = operation blocked and logged. MaxAgeDays is a configurable parameter (default 1 day per R12). Wildcard (∗) matches any requester or operation. 67
C.1 Processing elements of a representative artistic BCI installation (see also Figure 4.1). 74
C.2 Data flow enumeration for the artistic BCI installation DFD. E_1 = Experiential Exploitation; I = Information Disclosure; R = Repudiation; T = Tampering. 75
D.1 Threats to individual Counter-Alchemy Framework components. HBC = honest-but-curious threat model. 79
D.2 Graceful degradation under partial deployment. 80

D.3 Counter-Alchemy Framework threat coverage. S1–S5 = EEKC Stages. 80

Contents

Abstract **iii**

Acknowledgements **v**

List of Abbreviations **vii**

List of Figures **ix**

List of Tables **x**

Contents **xii**

1 Introduction **1**
1.1 Background 1
1.2 Research Problem 3
1.3 Research Questions 5
1.4 Significance of the Study 5

2 Literature Review **7**
2.1 BCI Technology in Artistic Contexts 7
2.1.1 Technical Foundations of Brain-Computer Interfaces 7
2.1.2 BCIs in Artistic and Creative Practice 8
2.2 Security and Privacy Frameworks for Neural Data 9
2.2.1 Classical Security Paradigms 9
2.2.2 BCI-Specific Security Research 9
2.2.3 Privacy-Enhancing Technologies and Their Limits . . 10
2.3 Ethical and Legal Frameworks for Neural Data Governance . 11
2.3.1 Privacy as a Normative Foundation 11
2.3.2 GDPR and Data Protection Law 12
2.3.3 The EU AI Act and Risk-Based Regulation 13
2.3.4 Neurorights and Cognitive Liberty 13

2.4 Critical Theory: Surveillance Capitalism and Experiential Labour 14
2.4.1 Surveillance Capitalism 14
2.4.2 Platform Capitalism and Digital Labour 14
2.4.3 Critical Design and Technical Resistance 15

3 Methodology 16
3.1 Research Design: Design Science Research 16
3.2 Alternative Methodologies Considered 17
3.3 Research Design: Phases and Evaluation 18
3.4 Data Sources and Ethics 19

4 Threat Modeling: Deconstructing the Neuro-Alchemy Chain 20
4.1 Data Flow Diagram for an Artistic BCI Installation 21
4.2 STRIDE-E: Extending Threat Classification with an Experiential Dimension 21
4.2.1 STRIDE Applied to the DFD: Baseline and Its Limits . 21
4.2.2 Defining the E Category: Experiential Exploitation . . 22
4.3 The Experiential Exploitation Kill Chain: A Five-Stage Model 23
4.4 STRIDE-E $\times$ EEKC Cross-Mapping Matrix 24
4.5 From Threat Model to Design Requirements 27

5 Counter-Alchemy Framework Design 29
5.1 Design Philosophy and Architecture 29
5.2 Layer 1: Source Capability Minimisation 30
5.2.1 Minimum Necessary Feature Set Declaration 30
5.2.2 Neural Obfuscation Circuit 31
5.3 Layer 2: Semantic Integrity Protection 31
5.3.1 Experience-Binding Hash 31
5.3.2 Context-aware Access Control 32
5.4 Layer 3: Governance and Lifecycle Management 33
5.4.1 Reverse-Clearance Protocol 33
5.4.2 Non-Monetary Accountability Protocol 33
5.5 Cross-Layer Components and Architectural Overview 34

6 Framework Validation and Feasibility Analysis 36
6.1 Validation Plan and Evaluation Criteria 36
6.2 Tier 1: Conceptual Validation 37
6.2.1 EBH Security Properties: Formal Arguments 37
6.2.2 EBH Prototype: Test Results 37
6.2.3 CAAC Policy Consistency: Analysis and Test Results . 38

6.2.4 NOC Functional Validation 40
6.2.5 Supplementary Tests 40
6.3 Tier 2: Empirical Feasibility Analysis 41
6.3.1 Main Experiment: Privacy-Utility Tradeoff on GAMEEMO 41
6.3.2 Supplementary Experiment: Cross-Session Re-Identification on SEED-IV 42
6.4 Tier 3: Scenario Walkthrough 44
6.4.1 Scenario Design 44
6.4.2 Walkthrough Summary 44
6.5 Limitations and Implementation Challenges 46

7 Archival Implications of Framework Governance Artefacts 48
7.1 Governance Artefacts as Archival Objects 48
7.2 The Deletion Certificate Paradox 49
7.3 Framework Mechanisms as Archival Policy Templates 49

8 Discussion 51
8.1 Addressing the Research Questions and Evaluation Criteria . 51
8.2 Contribution to the State of the Art 52
8.3 Implications for Information Security Practice 53
8.4 Implications for Neurorights and Cultural Governance 54
8.5 Limitations 54
8.6 Future Work 55
8.7 Declaration of Research and Writing Tools 56

9 Conclusion 58

Bibliography 60

Appendix A: Complete CAAC Reference Policy Set 67

Appendix B: Prototype Implementation Note 71

Appendix C: Threat Model Supplementary Material 72

Appendix D: Framework Design Supplementary Material 77

Appendix E: Validation Supplementary Material 83

1

Introduction

1.1 Background

Brain-Computer Interface (BCI) technology has undergone a dramatic transformation over the past five decades. Introduced by Vidal [1] as a framework for real-time communication between neural signals and computing machinery, BCIs were for many years confined to clinical and laboratory settings, where they served as assistive devices for individuals with motor impairments or as research tools in cognitive neuroscience [2, 3]. In these environments, neural data were processed under rigorous ethical oversight, with clearly defined therapeutic purposes and limited circulation beyond the immediate research context.

The commercial availability of low-cost, consumer-grade electroencephalography (EEG) headsets, including Emotiv EPOC, Muse, and OpenBCI, has substantially altered this landscape. These devices reduce the technical and financial barriers that previously restricted neurotechnology to specialist institutions, making it possible for artists, designers, and members of the public to interact with brain signals outside clinical or research environments [4, 5]. A notable consequence of this democratisation is the emergence of artistic BCI applications, in which participants' neural signals drive real-time audiovisual and generative outputs.

In a typical artistic BCI installation, scalp electrodes capture participants' electrical brain activity in real time; processing pipelines then translate these signals into aesthetic parameters [6, 7]. The outputs may include generative music, responsive visual environments, or adaptive haptic feedback, all of which change in response to the participant's moment-to-moment cognitive and emotional state.

Artistic BCI applications are frequently celebrated in both popular and academic discourse for their participatory qualities. By treating the participant's own neural activity as an expressive resource, such installations position the participant as a co-creator of the aesthetic experience. This framing is appealing precisely because it resonates with long-standing ideals in participatory art. However, it also serves to naturalise processes that, on closer inspection, involve the systematic extraction, transformation, and storage of extraordinarily intimate data about participants' mental lives.

Artistic BCIs are not a technically distinct category of device. They share the same EEG hardware, feature extraction pipelines, and machine learning inference components as consumer BCIs deployed in gaming, wellness, and educational contexts. What is distinctive about the artistic context is the constellation of conditions that allows typical threats to be systematically amplified, legitimised, and rendered invisible.

At the operational level, the boundary between functional necessity and semantic excess is maximally ambiguous. In a clinical BCI, the purpose of feature extraction is defined by therapeutic goals; in an artistic installation, the declared purpose is aesthetic experience, which provides no principled upper bound on how much neural data is 'necessary'. At the semantic level, potential expansion involves progressive deepening of neural data from raw signals into emotion scores, engagement profiles, and longitudinal models. This is often not treated as a violation in artistic contexts but as a feature: 'your inner state is being visualised' is experienced as participation, not surveillance.

At the governance level, artistic settings operate with notably weak governance infrastructure among consumer BCI deployments: no institutional review board, no clinical compliance framework, no persistent service agreement, and participants positioned as audience members rather than data subjects exercising rights. Audience members at a gallery or festival may encounter a BCI installation with little more than a brief placard explaining that their brainwaves will be used to generate the artwork. The commercial and reputational incentives of platform operators, curators, and technology providers are not necessarily aligned with the informational interests

of participants, yet governance mechanisms to address this misalignment remain immature.

The focus on artistic BCI contexts is therefore a deliberate scoping decision. Artistic BCIs constitute the most exposed case where experiential exploitation is most easily initiated, least likely to be detected, and most resistant to correction through existing technical or legal instruments. The threat model and defensive mechanisms are potentially applicable to other consumer BCI deployments in which similar challenges of semantic ambiguity, commercial infrastructure, governance weakness, and participant trust are present.

Information security's dominant paradigm, the Confidentiality-Integrity-Availability (CIA) triad [8], operates at an access-centric abstraction and does not model the semantic transformation of meaning across processing stages, nor the experiential dimensions of harm that arise when participants' cognitive and affective states are appropriated without their anticipation or authorisation.

Addressing the security challenges of artistic BCIs requires extending existing frameworks, both technical and normative, to account for the experiential layer of neural data processing. The concept of contextual integrity, developed by Nissenbaum [9, 10], provides a starting point: it holds that privacy is violated not simply by information disclosure but by the violation of context-appropriate norms governing who may access what information for which purposes. In artistic BCIs, contextual integrity is particularly difficult to apply: unlike gaming or wellness BCIs, whose functional necessity is defined by their mechanics, an artistic installation's functional necessity is open-ended and not easily externally auditable. Extending this concept to artistic BCIs means treating the experiential context of a BCI installation as a defined information sphere, within which participants' neural signals may legitimately serve aesthetic purposes, but beyond which their extraction, semantic deepening, valuation, and cross-context circulation constitute exploitation.

1.2 Research Problem

The central problem this thesis addresses is what may be termed the 'neuro-alchemy chain': a socio-technical process whereby raw, often unconscious neural traces are extracted, refined into higher-order semantic features such as inferred emotions, engagement levels, or cognitive signatures, mapped onto aesthetic and commercial value, and potentially recirculated across

contexts in ways that serve system-level objectives misaligned with participant autonomy. The term 'alchemy' is deliberate: like alchemical transmutation, the process converts something unstructured and personal—specifically a participant's momentary neural state—into a commodity of increasing value at each processing stage.

This thesis identifies 'experiential exploitation' as a specific threat category arising from this chain. Experiential exploitation occurs when unconscious cognitive and affective states are systematically appropriated, semantically re-interpreted, valuated, and circulated across contexts. It arises under conditions of immersive engagement and institutional power asymmetry. This is distinct from classical privacy violations in that it may occur entirely within the boundaries of declared artistic purposes, without any unauthorised data access or breach. A platform that legitimately collects neural data may simultaneously extract emotion scores for training affect-recognition models, create longitudinal engagement profiles, or sell comparative metrics to advertisers, all without violating its stated terms of use. This illustrates the gap between formal permission and contextual legitimacy that this thesis addresses. The research objective is thus to make experiential exploitation definable, designable, and verifiable.

Existing technical frameworks are not well-equipped to prevent this form of exploitation. Privacy-Enhancing Technologies (PETs) such as differential privacy [11], federated learning [12], and blockchain-based audit mechanisms [13] protect against data breaches and unauthorised aggregation but do not constrain the semantic operations conducted within legitimately authorised processing pipelines.

Legal instruments face analogous limitations. The General Data Protection Regulation (GDPR) mandates purpose limitation and consent [14], but its enforcement depends on technically demanding audit access that regulators rarely possess [15, 16]; the EU AI Act's transparency obligations under Article 50 [17] do not constrain semantic over-extraction within declared purposes. Neurorights scholarship has articulated normative commitments to cognitive liberty and mental privacy [18, 19], but these remain without deployable technical operationalisation.

The result is a governance and technical gap at the intersection of avant-garde artistic practice, commercial exhibition platforms, and emerging neurotechnology markets. Artistic BCIs operate in a regulatory space that lacks both the stringent procedural safeguards of clinical research and the mature security architectures of mainstream digital platforms. This thesis develops a threat-informed defense framework designed to address this gap,

treating experience itself as a security boundary and operationalising contextual and experiential constraints in both technical and governance mechanisms.

1.3 Research Questions

The thesis is structured around one main research question and four sub-questions.

Main Research Question: How can artistic Brain-Computer Interfaces be secured against experiential exploitation through a threat-informed defense framework that preserves the contextual integrity of neural data?

The following sub-questions guide the investigation:

- **Sub-Question 1:** How can experience-oriented exploitation risks in artistic BCI systems be systematically identified and modelled across the neural data lifecycle?
- **Sub-Question 2:** What design principles and technical mechanisms are required to enforce contextual integrity and participant agency in artistic BCI systems?
- **Sub-Question 3:** To what extent can the proposed framework demonstrate technical feasibility and preliminary effectiveness through proof-of-concept implementations?
- **Sub-Question 4:** How does this technical framework inform broader discourses on neurorights and cultural governance of neural data?

1.4 Significance of the Study

This research makes four contributions to the fields of information security, human-computer interaction, and neuroethics.

First, it introduces the Experiential Exploitation Kill Chain (EEKC), a five-stage threat model specific to artistic BCI deployments that extends existing kill-chain frameworks [20] to account for the semantic and experiential dimensions of neural data processing.

Second, it extends the widely used STRIDE threat classification [21, 22] with a seventh category, Experiential Exploitation (E_1). It makes authorisation-preserving misuse structurally visible within the threat modelling process.

Third, the thesis proposes and preliminarily validates the Counter-Alchemy Framework, a three-layer defense architecture providing source capability minimisation (Layer 1), semantic integrity protection (Layer 2), and governance and lifecycle management (Layer 3). It also introduces the Over-Extraction Ratio (OER) as a quantitative metric that operationalises data minimisation as a measurable engineering target.

Fourth, by grounding the framework in Nissenbaum's [9, 10] contextual integrity theory and integrating insights from surveillance capitalism scholarship [23, 24], the research demonstrates how critical social theory can be translated into deployable technical design principles.

For ease of cross-reference, the three technical contributions are designated C1 (EEKC), C2 (STRIDE-E), and C3 (Counter-Alchemy Framework) in the remainder of this thesis; the fourth contribution constitutes a methodological foundation that underpins all three.

2

Literature Review

2.1 BCI Technology in Artistic Contexts

2.1.1 Technical Foundations of Brain-Computer Interfaces

A Brain-Computer Interface is a system that establishes a direct communication pathway between neural activity and an external device, bypassing conventional neuromuscular channels [2]. The most widely used non-invasive signal acquisition modality in the consumer applications is electroencephalography (EEG), which measures electrical potentials generated by synchronised cortical neuron populations via electrodes placed on the scalp. EEG offers high temporal resolution, a non-invasive form factor, and progressively lower equipment costs, making it suitable for the kinds of mobile, participatory settings typical of artistic installations [5].

The standard BCI processing pipeline involves four stages: signal acquisition and amplification, preprocessing to remove artifacts from eye movements, muscle activity, and electrical interference, feature extraction to isolate task-relevant components such as event-related desynchronisation in alpha and beta frequency bands, and output mapping that translates extracted features into control commands or aesthetic parameters[2, 25]. In active and reactive BCIs, users generate specific mental states to produce intended system responses. Passive BCIs, by contrast, monitor cognitive and affective states continuously without requiring deliberate effort [26]; they are commonly deployed in artistic contexts because they do not demand that participants learn or maintain specific mental strategies.

Affective computing techniques have extended the scope of neural feature extraction well beyond motor signals. Public EEG datasets (e.g., DEAP [27]) collected during emotionally evocative tasks are widely used as benchmarks for affective BCI research. Models trained on such datasets can infer emotional states from neural signals with increasing accuracy, though they remain sensitive to individual variability and recording conditions. The combination of passive monitoring, real-time affective inference, and ubiquitous low-cost EEG hardware creates technical preconditions for the exploitation risks this thesis examines. The physiological computing framework [7] formalises this inferential chain from signal to psychological construct, making explicit the probabilistic assumptions underlying affective inference and their ethical dimensions.

2.1.2 BCIs in Artistic and Creative Practice

The intersection of neurotechnology and artistic practice dates back to the 1960s. Early experiments used EEG signals to control acoustic events, establishing the basic principle that neural signals could serve as a medium for aesthetic expression [28]. Since then, a growing body of artistic work has explored the expressive potential of neural signals across creative and interactive domains.

Nijholt [4] provides a comprehensive survey of brain-art practices and their technical underpinnings, cataloguing works in which participants' neural signals drive sound synthesis, generative imagery, robotic sculpture, and collaborative digital environments. A recurring theme is framing neural signals as a new expressive modality that enables more authentic or intimate forms of creative participation. Brain-art is characterised as an emerging genre that challenges traditional boundaries between artist, medium, and audience [29]. More technically oriented, Schreiner et al. [6] document implementations in which BCI systems drive wearable garments and screen-based displays in real time, demonstrating the technical maturity of such applications.

Despite this growth, the security and ethical dimensions of artistic BCIs have received rather little systematic attention in the literature. Gruber [30] calls for a more critically reflexive neuroart practice that interrogates the assumptions embedded in neuroscientific worldviews, but does not develop a security analysis. Nijholt [4] acknowledges privacy concerns in passing but treats them as secondary to technical and aesthetic considerations. No surveyed work systematically models the artistic BCI workflow as a potential exploitation pipeline in which each processing stage can

instrumentalise experience for system-level goals misaligned with participant autonomy.

2.2 Security and Privacy Frameworks for Neural Data

2.2.1 Classical Security Paradigms

The CIA triad [8] addresses confidentiality, integrity, and availability but operates at an access-centric abstraction insufficient for the artistic BCI context: it does not capture the experiential and semantic dimensions of harm arising from contextual norm violations. STRIDE [21, 22] classifies threats into six categories and has been extended for domain-specific applications [31, 32], but none of these extensions model exploitation conducted entirely within authorised boundaries. The kill chain model [20] and attack trees similarly presuppose adversarial actors operating outside the system.

2.2.2 BCI-Specific Security Research

Table 2.1 summarises the principal BCI-specific security contributions. These works address important threat categories but share a common limitation: they treat neural data primarily as information requiring confidentiality protection, without modelling the semantic transformation of experience that occurs across the processing pipeline.

Table 2.1: BCI-specific security research and shared limitation.

Study	**Threat Category**	**Method**	**Limitation re: semantic exploitation**
Martinovic et al. [33]	Side-channel disclosure	P300-elicited stimulus covert embedding	Addresses involuntary disclosure, not authorised-boundary exploitation
Zhang et al. [34]	Adversarial perturbation	Crafted visual stimuli	Addresses signal integrity, not semantic deepening
Ienca & Haselager [35]	Brainjacking (implanted BCIs)	Neurosecurity survey	Focuses on implants; no consumer/artistic BCI scope
Bidgoly et al. [36]	Re-identification risk	federated learning (FL)-based EEG authentication	Provides confidentiality; does not constrain downstream inference use
Agarwal et al. [37]	Inference attacks	Differential privacy	Addresses statistical queries; does not prevent initial feature extraction

The first research gap is revealed here: existing BCI security research models signal-level threats and external adversaries but does not capture exploitation within authorised boundaries.

2.2.3 Privacy-Enhancing Technologies and Their Limits

Differential privacy (DP) [11] limits inference from aggregate queries by adding calibrated random noise. However, DP cannot prevent the initial extraction of sensitive features from raw signals: a DP mechanism on model outputs does not prevent internal storage of un-noised emotion scores,

and DP guarantees do not extend to the full range of semantic inferences drawable from a neural data archive [38].

Federated learning (FL) [12] enables collaborative training without centralising raw data. However, decentralising training data does not decentralise control of inference outputs: the operator remains free to use model predictions for comparative valuation, engagement optimisation, or metric sales [39].

Blockchain-based audit mechanisms [13] create tamper-evident processing records, providing ex-post accountability but not ex-ante prevention of contextual boundary violations; audit records are useful only insofar as participants can interpret and act on them.

A common blind spot in the application of existing PETs is what may be termed 'semantic blindness': the implicit assumption that once data collection is legally authorised, subsequent processing operations are inherently legitimate rather than potential sites of exploitation. Consequently, these systems provide little protection against semantic deepening and longitudinal profiling conducted within a single authorised processing pipeline. This second research gap motivates the Layer 2 semantic integrity protection layer of the Counter-Alchemy Framework.

2.3 Ethical and Legal Frameworks for Neural Data Governance

2.3.1 Privacy as a Normative Foundation

Privacy scholarship offers multiple frameworks for understanding when violation constitutes harm. Early study [40] characterise privacy as the individual's right to control information about themselves, this conception underpins much of subsequent data protection law. Solove [41] developed a taxonomy of privacy harms, identifying categories such as aggregation, secondary use, and decisional interference that go beyond simple disclosure.

Nissenbaum [9, 10] articulated contextual integrity as the normative principle that information flows are appropriate when they conform to the norms of the context in which information is originally shared. A medical record shared within a healthcare context may be appropriate, while the same information disclosed to an employer violate contextual norms even if technically authorised. Contextual integrity theory has proven useful for analysing privacy violations in digital environments because it captures the

relational and context-dependent character of privacy expectations. This thesis applies this framework to the experiential domain, arguing that a participant's neural signals shared in the context of an artistic installation are subject to contextual norms. They permit aesthetic use but prohibit semantic deepening, comparative valuation, or cross-context circulation.

2.3.2 GDPR and Data Protection Law

The General Data Protection Regulation (GDPR) [14] establishes a comprehensive framework for personal data protection across the European Union, applicable to all processing activities that target EU residents regardless of the processor's location. Key GDPR provisions relevant to artistic BCIs include: the purpose limitation principle (Article 5(1)(b)), which restricts processing to declared collection purposes; the data minimisation principle (Article 5(1)(c)), which requires collection be limited to what is necessary; and the consent requirement (Article 7), which demands freely given, specific, informed, and unambiguous agreement to processing.

GDPR classifies biometric data used for the purpose of uniquely identifying a natural person as a special category of personal data subject to heightened protection (Article 9). EEG signals may qualify as biometric data for these purposes, and they may also constitute health data depending on the features extracted and the processing purpose [42]. Rainey et al. [43] assesses the adequacy of GDPR for neurotechnology and identified significant limitations, including the GDPR's dependence on ex-post enforcement, the semantic vagueness of 'compatible processing', and the difficulty of determining whether particular analytical operations constitute new purposes. Building on this, the protection of mental data under GDPR is specifically examined [44], arguing that existing provisions are insufficient to protect the distinctive intimacy of neural information.

The right to explanation is examined for automated decision-making under GDPR, existing provisions are found to provide weaker protections than often assumed [45]. Their analysis is pertinent to the artistic BCI context because it highlights the general difficulty of enforcing purpose limitations against algorithmic processing that operates as a black box. Zarsky [16] identifies structural tensions between data minimisation requirements and the logic of big-data analytics, these tensions are not readily resolved through legal interpretation alone and require technical interventions.

2.3.3 The EU AI Act and Risk-Based Regulation

The EU Artificial Intelligence Act [17] establishes transparency obligations for providers of emotion recognition systems under Article 50, regardless of whether a system qualifies as high-risk under Annex III. Providers must ensure that natural persons subject to emotion recognition are informed of this fact before or at the point of exposure. Artistic BCI installations that infer emotional states from neural signals would fall within the scope of this requirement.

However, Article 50's transparency obligation is a disclosure requirement, not a data minimisation mechanism. An operator who informs participants that emotion recognition is occurring remains free to extract features beyond functional necessity, accumulate longitudinal profiles, and circulate derived models across contexts. More fundamentally, compliance with Article 50 can be demonstrated by showing notification was issued; yet whether emotional inference remains within declared scope can only be verified through technical auditing of algorithmic pipelines. Neither participants nor regulators can routinely exercise this capacity. This gap between normative obligation and technical enforceability points toward the need for domain-specific mechanisms. Such mechanisms should improve compliance auditability and constrain contextual boundary violations through technical and procedural controls.

2.3.4 Neurorights and Cognitive Liberty

A parallel strand of normative work has advocated for neurorights: a set of fundamental rights specifically designed to protect individuals from harms arising from neurotechnology. Four ethical priorities for neurotechnologies and AI are identified: mental privacy, personal identity, free will, and equitable access [18]. Four neurorights are proposed: mental privacy, cognitive liberty, mental integrity, and psychological continuity [46]. Ligthart et al. [19] map the ethical and legal foundations of neurorights across multiple jurisdictions and found that while existing legal frameworks provide some relevant protections, significant implementation gaps remain.

Chile became the first country to enact neurorights legislation through a constitutional amendment in 2021, subsequently supplemented by implementing legislation. This framework's application is analysed in a landmark Supreme Court ruling involving unauthorised processing of EEG data, demonstrating both the potential and the limitations of constitutional neurorights protection [47]. Sommaggio et al. [48] examines cognitive liberty

as a foundational principle for neurorights, arguing that individuals must retain the right to control the states and contents of their own minds, including the freedom to decline neural monitoring. Kellmeyer [49] identifies persistent challenges in brain data governance, including meaningful consent, scope creep, and secondary use protection.

These proposals articulate the normative principles that this thesis seeks to operationalise. However, the third research gap is presented: they remain largely conceptual and provide little deployable technical specifications suited to the conditions of artistic BCI deployments.

2.4 Critical Theory: Surveillance Capitalism and Experiential Labour

2.4.1 Surveillance Capitalism

Surveillance capitalism [23] describes a new economic logic in which the systematic extraction and processing of human behavioural data serves as the primary mechanism of capital accumulation. Under this logic, human experience is not merely a resource to be passively observed but is actively modified through the design of digital environments to produce more predictable and monetisable behavioural data. The term 'behavioural surplus' [23] points directly the data extracted beyond what is needed to provide a service, is claimed by platform operators as raw material for prediction products sold on behavioural futures markets.

In the artistic BCI context, neural data collected during an installation constitute potential behavioural surplus. They contain far more information than is needed for aesthetic output, and the artwork is the product offered to participants while their neural data are the product sold to other parties.

2.4.2 Platform Capitalism and Digital Labour

Platform capitalism [24] theorises platforms as an economic infrastructure in which a central intermediary controls access to a two- or multi-sided market, extracting value from the interactions and data generated by participants on both sides. Platform operators have strong incentives to maximise data collection because the value of behavioural data increases with scale and diversity.

The concept of free labour [50] describes how digital platforms extract value from users' online activities, framing users' contributions as a form of

unwaged work. This analysis is extended to digital media broadly [51], arguing that the production of audience attention and behavioural data constitutes a form of exploitation. The term 'affective labour' [52] describes work that produces or manipulates affects, human feelings and relationships.

These theoretical frameworks converge on the artistic BCI context. Exhibition platforms that aggregate and extract value from participants' neural data occupy a structural position analogous to social media platforms. Participants' affective engagement constitutes unwaged labour whose products are appropriated by platform operators. This constitutes the fourth research gap: critical theory rarely produces concrete security architectures, and translating critique into enforceable system properties remains limited.

2.4.3 Critical Design and Technical Resistance

Critical design scholarship provides methodological tools for translating social critique into technical interventions. Speculative design [53] is developed as a practice that uses design artefacts to question assumptions, expose possibilities, and stimulate reflection on the social and political implications of technology. The concept of critical design within Human-Computer Interaction (HCI) [54] argues that critical approaches must move beyond description to intervention, producing designs that resist or subvert extractive logics.

Winner [55] argues that certain technologies are designed in ways that embody and perpetuate particular politics and power relations. Value-sensitive design [56] is proposed as a methodology for systematically incorporating human values into the design of technological systems. This thesis draws on these traditions, treating participant agency and contextual integrity as first-class design requirements, rather than applying ethics as a post-hoc add-on.

3

Methodology

3.1 Research Design: Design Science Research

Design Science Research (DSR) is a research paradigm that aims to create and evaluate innovative artefacts that solve problems in specific application domains [57]. Unlike behavioural science research, which seeks to develop theories that explain and predict phenomena, DSR aims to produce artefacts, including constructs, models, methods, and instantiations, that extend human capabilities by enabling the construction of previously impossible solutions. The rigour of DSR is established through the process of artefact design and evaluation rather than through hypothesis testing.

This thesis follows the five-step DSR process of Johannesson and Perjons [58]: problem explication, requirements definition, design and development, demonstration, and evaluation. These five steps are operationalised in this thesis as four phases (Sections 3.3–3.6). The requirements definition and design steps were applied iteratively between threat modelling and framework design, with each informing and refining the other.

DSR is selected for three reasons. First, the thesis aims to produce an innovative artefact, namely the Counter-Alchemy Framework, that addresses a genuine and poorly understood problem requiring both analytical and design work. Second, the artistic BCI context is characterised by complex socio-technical dynamics that resist simple experimental study. There are no well-defined performance benchmarks for experiential exploitation prevention, and the relevant stakeholders, including artists, institutions, participants, and regulators, are heterogeneous and difficult to assemble for

controlled studies. DSR's emphasis on artifact-based knowledge creation is well-suited to contexts where the design of new solutions is itself a form of knowledge contribution.

Per standard DSR practice [57], three evaluation criteria are declared at the outset of the design phase.

Utility: the framework reduces exploitable semantic content while preserving sufficient signal quality for the aesthetic function. Privacy gain is operationalised as the reduction in adversarial emotion inference accuracy; utility cost is operationalised as normalised mean squared error between processed and unprocessed feature vectors (Section 6.3.1). Evaluated in Tier 2.

Feasibility: core mechanisms are implementable within real-time constraints at prototype level. Evaluated in Tier 1 prototype tests.

Conceptual Completeness: for every threat instance in the STRIDE-E cross-mapping matrix, the framework provides a corresponding defensive mechanism. This criterion assesses systematic threat coverage within the STRIDE-E analysis, but does not claim exhaustive defense against all possible attack vectors. Residual gaps are explicitly documented. Evaluated in Tier 1 mapping and Tier 3 walkthrough.

3.2 Alternative Methodologies Considered

This research has three requirements: formalising a novel threat category (E_1) within established security frameworks, constructing technical countermeasures, and demonstrating their feasibility under realistic constraints.

Case study research, in the tradition of Yin [59], excels at producing rich contextual understanding of bounded phenomena. However, it is primarily explanatory, which means it produces theory about how and why phenomena occur rather than constructing technical artefacts. Practically, accessing the system logs, data handling agreements, and operator records necessary for rigorous case analysis was not feasible within this project's constraints.

Action research [60] offers a collaborative model in which the researcher works alongside practitioners through iterative cycles of diagnosis, intervention, and reflection. However, action research requires sustained access to a willing organisational partner. This relationship could not be established within this project's scope. More fundamentally, experiential exploitation is not yet theorised or widely recognised as a problem among

practitioners in the artistic BCI space, making a collaborative problem-diagnosis cycle difficult to initiate before the problem itself has been articulated.

DSR directly addresses all three requirements. Its rigour cycle supports the formalisation of E_1 within existing threat modelling practice, the design cycle produces the Counter-Alchemy Framework as a novel technical artefact, and the relevance cycle grounds the design in the operational constraints of artistic BCI deployments. Critically, DSR permits the researcher to theorise and model a problem ahead of practitioner consensus.

3.3 Research Design: Phases and Evaluation

The four DSR phases are summarised here; full details appear in the corresponding chapters.

Phase 1 – Problem Explication (Ch. 2): Systematic literature review across ACM Digital Library, IEEE Xplore, Springer, and Google Scholar using search terms including 'brain-computer interface security', 'EEG privacy', 'artistic BCI', 'experiential exploitation', 'neurorights', and 'contextual integrity', supplemented by backward citation tracking from key papers. Case analysis of documented artistic BCI installations to ground the threat model in realistic deployment scenarios; the literature review informed the threat taxonomy and normative framework, while the case analysis informed the Data Flow Diagram (DFD) and operator threat model.

Phase 2 – Threat Modelling (Ch. 4): STRIDE [21, 22] is extended with a seventh category, Experiential Exploitation (E_1). The five-stage EEKC [20] models the exploitation lifecycle within authorised boundaries. The STRIDE-E $\times$ EEKC cross-mapping matrix (Table 4.4) bridges threat analysis to design requirements.

Phase 3 – Framework Design (Ch. 5): MoSCoW (Must-have, Should-have, Could-have, Won't-have) prioritisation and critical design exercises translate the identified threat requirements into a modular three-layer defensive architecture: a source capability minimisation layer, a semantic integrity protection layer, and a governance and lifecycle management layer.

Phase 4 – Evaluation (Ch. 6): Three complementary tiers. *Tier 1* conceptual validation (minimal Python prototypes, 38 automated checks):

(a) Existential Unforgeability under Chosen-Message Attacks (EUF-CMA) correctness of the cryptographic context-binding mechanism; (b) functional correctness of the frequency-domain filtering mechanism; (c) consistency and completeness of the policy enforcement mechanism, verifying no conflicting rules; (d) non-arbitrariness of the declared minimum feature set boundary. *Tier 2* empirical feasibility analysis on two public EEG datasets [61**?**]: privacy gain is operationalised as the reduction in adversarial arousal classification accuracy; utility cost as the normalised mean squared error between processed and clean features. Four obfuscation conditions are compared to isolate each mechanism's contribution and characterise the privacy-utility tradeoff. *Tier 3* scenario walkthrough verifies the framework's coverage of defensive response; GDPR and EU AI Act regulatory correspondence mapping.

3.4 Data Sources and Ethics

GAMEEMO [61] (28 participants, four video game conditions eliciting distinct arousal states, Emotiv EPOC 14-channel consumer-grade EEG headset) is selected on grounds of device equivalence and experiential structure equivalence; the gaming stimuli represent an upper bound on arousal signal strength relative to passive gallery viewing. DREAMER [62] (23 participants, Emotiv EPOC, film-clip stimuli) is used to validate the non-arbitrariness of the declared minimum feature set boundary. SEED-IV [63] (15 participants, 62-channel EEG, three recording sessions, 1,080 trials) enables cross-session re-identification analysis.

GAMEEMO is available under a Creative Commons licence permitting academic use; DREAMER through Zenodo; SEED-IV through the SJTU BCMI laboratory portal under standard academic use terms. All datasets contain EEG recordings from healthy adult participants who provided informed consent; no clinical data, sensitive demographics, or personally identifying information are included. No attempt is made to re-identify any participant; datasets were used solely for the analytical purposes described in their respective access agreements. No primary fieldwork or human participant observations are conducted in this research.

4

Threat Modeling: Deconstructing the Neuro-Alchemy Chain

The threat actor is modelled as the **honest-but-curious operator**: a platform operator who complies with declared consent but exploits every technically permitted operation for secondary gain. Table 4.1 summarises the threat model scope.

Table 4.1: Threat model scope and assumptions.

Assumption	**Detail**
Threat actor	Honest-but-curious operator (artist, platform provider, or both); controls backend infrastructure
In scope	Semantic over-extraction, dual-use pipelines, longitudinal profiling, decontextualisation within declared permissions
Out of scope	Hardware supply-chain attacks; malicious operators actively circumventing protections
Assumptions	Unified administrative domain; system time not manipulated

4.1 Data Flow Diagram for an Artistic BCI Installation

Figure 4.1 shows the DFD for a representative artistic BCI installation. The system contains six processing elements (P1–P6), three data stores (DS1–DS3), and data flows across a trust boundary separating the participant-visible pipeline (P1–P5, DS1–DS2) from the operator-controlled backend (P6, DS3); this reflects participant visibility, not technical isolation. Data flow identifiers DF1–DF8 are used throughout the threat analysis; full component and data flow specifications are in Appendix C (C.2).

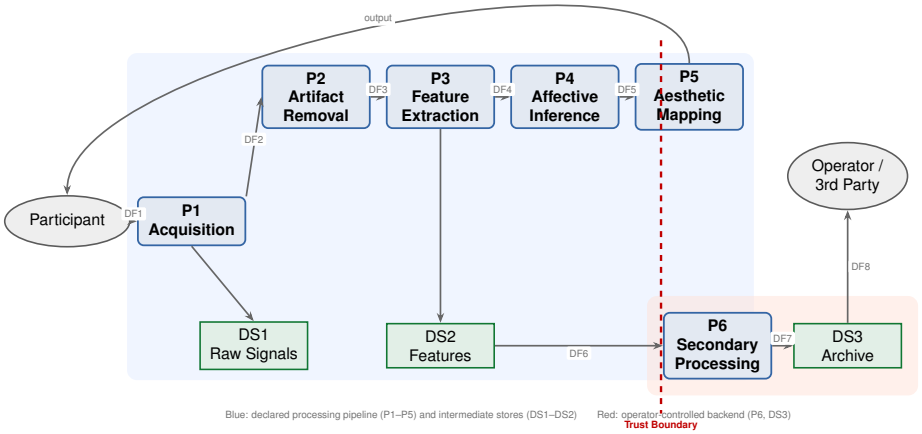


Figure 4.1: Data Flow Diagram for a representative artistic BCI installation.

4.2 STRIDE-E: Extending Threat Classification with an Experiential Dimension

4.2.1 STRIDE Applied to the DFD: Baseline and Its Limits

Applying STRIDE to the DFD (Figure 4.1) yields the baseline threat instances: Information Disclosure at DF4 (alpha-band re-identification [33, 36]); Tampering at DF2–DF3 (adversarial perturbation [34]); Repudiation at P3/P4/P6 (absent logging); Elevation of Privilege at the P5–P6 boundary. These instances share a structural assumption that limits their relevance: they all involve unauthorised actors or boundary-violating operations. The aesthetic mapping component P5 is authorised to read the minimum declared feature set and produce soundscape parameters. P5 also computes, as

an internal variable, a weighted combination of theta features and uses this value to systematically modulate stimulus parameters in ways not disclosed to participants. No data leaves P5, no new storage is created, no privilege is elevated. Yet the participant's neural state is being repurposed for a secondary objective without informed consent. This exploitation is not captured by classical STRIDE: a structural blind spot that motivates the E_1 category.

An alternative would be to adopt the privacy-specialised threat framework LINDDUN [64]. However, it does not map onto system components or compose naturally with a lifecycle kill chain model. STRIDE's component-oriented structure is retained here as it supports both DFD-based threat tracing and the EEKC's stage-by-stage propagation logic; E_1 adds the missing semantic-exploitation category without sacrificing these structural advantages.

4.2.2 Defining the E Category: Experiential Exploitation

Experiential Exploitation (E) is defined as the systematic use of authorised access to participants' neural data, enabling extraction and downstream processing (through deepening, valuation, or circulation) of information about their cognitive or affective states. It does so in ways that exceed the declared functional scope and violate contextual integrity. The exploitation serves system-level objectives misaligned with participant autonomy, without necessarily triggering any of the six conventional STRIDE threat categories.

E_1 is proposed as a structural extension of STRIDE, not a mathematically closed category. Three constitutive conditions must hold jointly:

Condition	**Definition**
Authorisation preservation	Exploitation uses legitimate access; distinguishes E_1 from I (unauthorised exposure) and E_2 (unauthorised capability)
Semantic transformation	Neural data is extracted or re-interpreted beyond what the declared aesthetic function requires
Contextual integrity violation	Data flows to processing nodes inconsistent with the declared interaction context [9, 10]

The structural independence of E_1 can be stated simply: a system can exhibit zero violations of all six original STRIDE categories while systematically conducting experiential exploitation. STRIDE is therefore necessary

but not sufficient for the artistic BCI threat context. This is the blind spot STRIDE-E is designed to close.

E-category threats are characterised by the relationship between the Minimum Necessary Feature Set (MNFS), features strictly required for the declared aesthetic purpose, and the Actual Extracted Feature Set (AEFS). An E-category threat exists wherever AEFS $\supsetneq$ MNFS. The severity is quantified using the Over-Extraction Ratio (OER):

$$\text{OER} = \frac{|\text{AEFS} \setminus \text{MNFS}|}{|\text{MNFS}|} \tag{4.1}$$

where $|\cdot|$ denotes the count of feature dimensions. OER is a heuristic indicator of over-extraction severity capturing dimensional excess; the semantic depth of excess features constitutes an additional qualitative dimension not captured by OER alone.

Three judgment rules distinguish E_1: (1) if the process involves unauthorised access or boundary-crossing, classify as I or E_2 instead; (2) if a component exercises an undeclared capability, classify as E_2; (3) if data exits to an unauthorised party, classify as I. E_1 covers semantic operations entirely within the authorised system boundary.

4.3 The Experiential Exploitation Kill Chain: A Five-Stage Model

The EEKC operationalises the neuro-alchemy chain introduced in Section 1.2, providing a formal five-stage model of how neural data is extracted and progressively enriched into exploitable semantic assets. It adapts kill chain methodology [20] to the experiential domain: where traditional kill chains model external adversarial intrusion, the EEKC models value extraction within authorised boundaries. These stages are conceptual abstractions; adjacent stages may overlap and represent a typical non-mandatory progression. Figure 4.2 summarises the five stages; detailed stage descriptions with empirical evidence are in Appendix C.

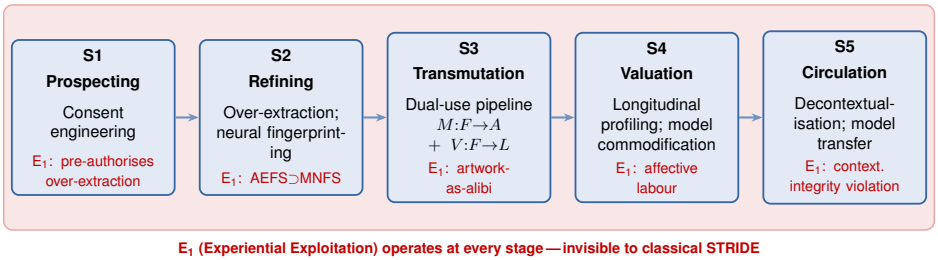


Figure 4.2: The Experiential Exploitation Kill Chain (EEKC): five-stage model of authorisation-preserving exploitation.

4.4 STRIDE-E × EEKC Cross-Mapping Matrix

STRIDE-E classifies threat types by structural properties; the EEKC explains how they unfold over time. Table 4.2 connects both frameworks, informing the Counter-Alchemy Framework design in Chapter 5. Each shaded cell corresponds to a defensive requirement. For readability, each instance is placed under its most prominent STRIDE-E classification, although category overlap may occur.

Table 4.2: STRIDE-E × EEKC Cross-Mapping Matrix. E_1 = Experiential Exploitation (novel seventh category); E_2 = Elevation of Privilege. Em-dashes indicate non-characteristic intersections.

STRIDE-E	**Stage 1** Prospecting	**Stage 2** Refining	**Stage 3** Transmutation	**Stage 4** Valuation	**Stage 5** Circulation
Spoofing (S)	Participant identity spoofing; fabricated consent records	Signal injection via synthetic EEG at DF1–DF2	Misattribution of outputs to alter records	—	Identity spoofing in third-party transfers at DF8
Tampering (T)	—	Adversarial perturbation of EEG or Independent Component Analysis (ICA) output [34]	Modification of feature-to-mapping rules post-collection	Alteration of valuation scores in DS3	Retroactive reanalysis; modification of model provenance
Repudiation (R)	No audit trail for consent interface	No logs constraining P3 beyond MNFS	Absence of audit for secondary V operation	No logs linking model weights to sessions	Provenance loss: licensed models untraceable to participants

STRIDE-E	**Stage 1**	**Stage 2**	**Stage 3**	**Stage 4**	**Stage 5**
Information Disclosure (I)	Premature exposure of neural profiles	Feature vectors enabling neural fingerprinting [33, 36]	Leakage of hidden valuation tags	Cross-session profiling; membership inference [65]	Model inversion [66]; jurisdictional exposure of DS3
Denial of Service (D)	Consent-interface overload	—	—	—	Restriction of participant data-access rights
Elevation of Privilege (E_2)	Scope inflation via broadly worded consent	Capability extension beyond MNFS at P3	P5 codebase sharing with P6 enabling scope escalation	Model ownership concentration from aggregated data	Cross-context authority extension through opaque sharing
Experiential Exploitation (E_1)	**Narrowed consent; trust asymmetry**	**Semantic over-extraction: AEFS $\supset$ MNFS; feedback loop exploitation**	**Dual-use mapping; artwork-as-alibi**	**Longitudinal profiling; affective labour extraction**	**Decontextualization violating contextual integrity [9, 10]**

Two structural observations emerge. First, E_1 is the only category appearing at every EEKC stage, confirming its lifecycle-pervasive character. Second, Repudiation and Information Disclosure are densely populated at Stages 2–4, confirming that authorised processing without audit constraints is the dominant threat mechanism; this motivates the layered architecture in Chapter 5.

4.5 From Threat Model to Design Requirements

The cross-mapping matrix translates into four design requirements to which every framework mechanism is traceable.

R0 (Bound Declaration / External Assumption): The framework assumes the MNFS declaration accurately reflects the minimum features necessary for the aesthetic purpose; an over-broad declaration reduces E_1 detectability and constitutes a specification failure outside the framework's threat model. R0 is a design boundary condition rather than an implementable requirement.

R1 (Limit Extraction): A source-level mechanism must enforce extraction boundaries at the point of signal acquisition, preventing excess features from entering the pipeline.

R2 (Bind Context): A binding mechanism must cryptographically associate feature vectors with the declared purpose and installation context, enabling ex-post verification that features were produced within declared scope.

R3 (Enforce Semantic Boundaries): An access control mechanism must govern runtime operations on stored features, enforcing purpose limitation at the operation level and generating a tamper-evident audit record.

R4 (Participant Agency): Governance mechanisms must enable participants to revoke consent and trigger data deletion, and must make operator behaviour transparent and accountable to participants and external auditors.

Table 4.3 maps the requirements to specific mechanisms and their MoSCoW prioritisation. Technical specifications and implementation status are further illustrated in the following chapters. All mechanisms and their nomenclature are original proposals of this thesis.

Table 4.3: MoSCoW prioritisation of Counter-Alchemy Framework design requirements.

Requirement	**Mechanism**	**Priority**	**Status**
R1: Limit Extraction	Neural Obfuscation Circuit (NOC) + MNFS Declaration	Must-have	Implemented; validated in Tier 2
R2: Bind Context	Experience-Binding Hash (EBH)	Must-have	Implemented; validated in Tier 1
R3: Enforce Semantic Boundaries	Context-aware Access Control (CAAC)	Must-have	Implemented; validated in Tier 1
R4: Participant revocation (Phase 1)	Reverse-Clearance Protocol (RCP) Phase 1	Must-have	Implemented
R4: Model-level unlearning (Phase 2)	RCP Phase 2	Should-have	Architecturally specified; unimplemented in current prototype
R4: Transparency and accountability	Non-Monetary Accountability Protocol (NMAP) + Neural Data Use Report (NDUR)	Should-have	Specified; structurally integrated into Layer 3
Real-time responsiveness	Live NOC pipeline and streaming evaluation	Could-have	Not evaluated; future empirical work
Hardware-level signal protection	Hardware trust mechanisms	Won't-have	Excluded from software-layer proof-of-concept

5

Counter-Alchemy Framework Design

5.1 Design Philosophy and Architecture

The Counter-Alchemy Framework is designed according to four guiding principles from the threat analysis in Chapter 4 and value-sensitive design methodology [56]: (1) minimum necessary extraction (enforced technically through source-level filtering); (2) context binding (features carry verifiable metadata); (3) semantic auditability (every transformation produces tamper-evident audit evidence); and (4) participant agency without commodification (governance mechanisms enable revocation without financial transactions).

Figure 5.1 presents the three-layer architecture. The framework is modular: each layer deploys independently, enabling incremental adoption.

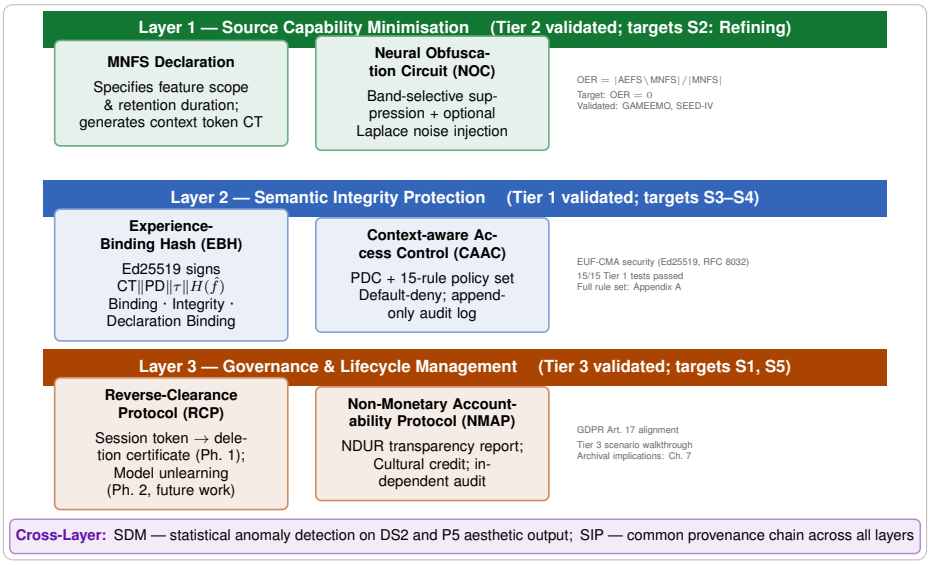


Figure 5.1: Counter-Alchemy Framework: three-layer architecture for authorisation-preserving exploitation defence.

5.2 Layer 1: Source Capability Minimisation

Layer 1 targets E_1, Information Disclosure, and Elevation of Privilege threats at Stage 2 of the STRIDE-E matrix (Table D.6 in Appendix C). Its primary objective is to enforce the MNFS boundary at the point of feature computation, preventing over-extraction before excess features can be stored, transmitted, or exploited by downstream components.

5.2.1 Minimum Necessary Feature Set Declaration

The first mechanism of Layer 1 is the formal declaration of the MNFS as a structured document specifying, for each installation, the complete set of features that P3 is authorised to compute and retain. The MNFS declaration has three components: a feature type list, a dimensionality specification, and a retention duration parameter. The running example uses six frontal theta-band channels (AF3, F7, F3, F4, F8, AF4; 4–8 Hz), yielding OER ≈ 10.67 relative to the full-device AEFS baseline (Section 6.1 provides the full calculation). An overly broad MNFS reduces Layer 1's effectiveness (a specification failure under R0); the NMAP and Semantic Drift Monitor (SDM) partially mitigate this through transparency and post-hoc statistical

detection. Reducing OER to zero under a genuinely minimal MNFS declaration removes a key structural precondition for E_1 exploitation.

5.2.2 Neural Obfuscation Circuit

The NOC is inserted between P2 and P3, enforcing the MNFS declaration in two sequential modes:

Mode	Mechanism	Privacy effect
Band suppression	Band-rejection filters remove all non-MNFS frequency bands	Eliminates neural fingerprinting signatures [36] as a side-effect of MNFS enforcement
Laplace noise injection (heuristic)	Calibrated noise added to within-MNFS features	Residual re-identification protection; ε is a tunable noise-scale parameter

5.3 Layer 2: Semantic Integrity Protection

Layer 2 addresses Repudiation and E_1 threats at Stages 3–4, where dual-use mapping and longitudinal profiling operate on stored features. Without Layer 2, no cryptographic record binds features to their declared purpose. Threat coverage: Table D.6 in Appendix C.

5.3.1 Experience-Binding Hash

The EBH is introduced as a cryptographic construction that attaches a verifiable context tag to each feature vector produced by P3. This ensures that the vector carries a cryptographically verifiable record of the context in which it was produced and the purposes for which it was authorised.

The EBH is defined as:

$$\text{EBH} = \text{Ed25519_Sign}\Big(sk,\ CT \parallel \text{PD_hash} \parallel \tau \parallel H(\hat{f})\Big) \tag{5.1}$$

where H is SHA-256, τ is the Unix timestamp, $\hat{f}$ is the feature vector, CT is the context token, sk is the operator's private signing key, and pk is published via NMAP before session commencement. Ed25519 is selected for its EUF-CMA security under standard assumptions [67, 68]. Keypair generation, parameter encoding, and storage formats are detailed in Appendix C.

The EBH binds features to purpose rather than participant identity (to avoid re-identification risk). It provides: (1) **Binding**—context change invalidates the signature; (2) **Integrity**—feature modification invalidates the signature; (3) **Declaration Binding**—any auditor can verify the feature was produced under a specific MNFS declaration using the published pk. Cryptographic arguments are in Section 6.2.1.

5.3.2 Context-aware Access Control

The CAAC governs runtime operations on DS2/DS3 via a Policy Decision Component (PDC) that evaluates each request against the registered policy set (15 rules; Appendix A). Figure 5.2 shows the decision flow. The context-awareness refers to the installation context encoded in the MNFS declaration and CT, not dynamic environmental sensing.

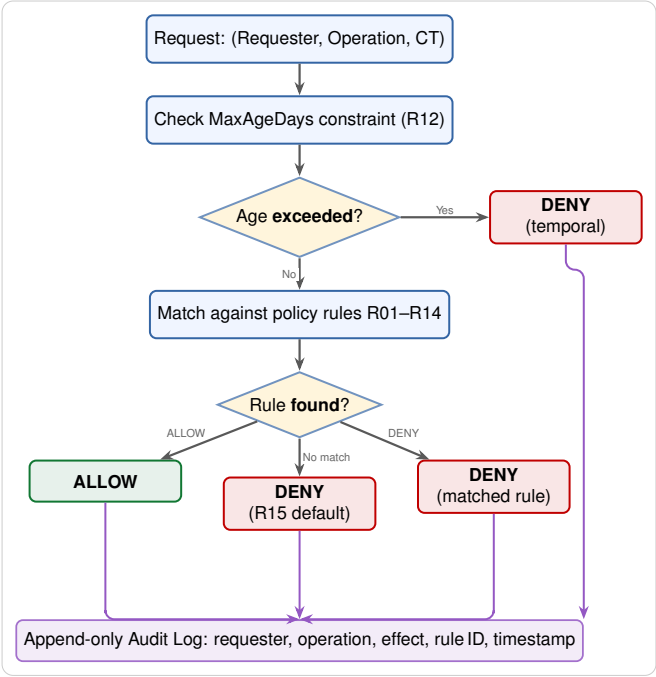


Figure 5.2: CAAC policy decision flow. Unmatched requests are denied by the default-deny posture (R15); all decisions are logged to the append-only audit log.

Policies are immutable after CT generation: any modification triggers a new declaration cycle, invalidating all prior EBH tags. The PDC enforces

policies mechanically; the NMAP-designated auditor serves as institutional interpreter.

5.4 Layer 3: Governance and Lifecycle Management

Layer 3 addresses governance-layer E_1 threats at Stages 1 and 5 that technical layers cannot prevent, making institutional choices visible, accountable, and contestable across the full data lifecycle. Threat coverage: Table D.6 in Appendix D.

5.4.1 Reverse-Clearance Protocol

The RCP enables participants to revoke consent and trigger data deletion after a BCI session, addressing the 'derived-model problem' that standard GDPR Article 17 deletion requests do not reach trained model weights.

Phase	Mechanism	Status	Output
Phase 1	Session token ST → PDC validates → feature-vector deletion	Implemented	Timestamped deletion certificate (compliance artefact; not a legal GDPR Art. 17 determination)
Phase 2	Machine unlearning of model weights	Specified; not yet implemented	Certified model update

The four-step revocation sequence is detailed in Appendix D (D.1); audit log entries are retained for non-repudiation.

5.4.2 Non-Monetary Accountability Protocol

The NMAP creates institutional incentives for compliance without reproducing the commodification logic of surveillance capitalism. Rather than compensating participants financially, the NMAP provides accountability through structured transparency obligations and cultural credit mechanisms.

The transparency component requires operators to publish a NDUR documenting: the MNFS declaration used; aggregate CAAC decision statistics; revocation outcomes; and any authorised secondary processing. Each NDUR includes at minimum: session identifier, context token CT, MNFS

feature scope, CAAC policy version, and session timestamps. The NDUR is derived from the audit log and is independently verifiable. Participants may opt in to standardised cultural credit acknowledgement (symbolic; non-transferable; does not affect data rights).

5.5 Cross-Layer Components and Architectural Overview

The System Integration Protocol (SIP) coordinates the three layers through three defined interfaces: the MNFS interface, which passes the context token CT from Layer 1 to the EBH in Layer 2; the audit-log interface, through which PDC decisions are written to the append-only log; and the session-token interface, linking ST to feature vector tuples at consent. Together, these interfaces ensure that declarations, access decisions, and revocation events share a common provenance chain. The SIP is a coordination specification rather than an independently deployable component; its correct operation is demonstrated through the successful integration of all three layers in the Tier 1 and Tier 3 evaluation activities.

The SDM operates as an auxiliary detection component (not primary enforcement); it triggers audit alerts but does not block operations.

Mode	**Detection method**	**Trigger condition**
DS2 monitoring	Periodic sampling of feature vectors; statistical comparison against MNFS declaration	Unexpected band-power shifts, dimensional increases, or cross-session drift
P5 output monitoring	Partial correlation between P5 output dimensions and session time index, controlling for MNFS features (Bonferroni-corrected)	Statistically significant residual correlation indicating hidden encoding

Component-level threats and graceful degradation behaviour are summarised in Appendix D (D.4 and D.5). The recommended minimum deployment is joint Layer 1 and Layer 2: without Layer 2, MNFS-constrained features remain accessible without access control enforcement; without Layer 1, Layer 2 cannot prevent over-extraction at source.

Before each session, CT is generated from the MNFS declaration hash and participant session tokens ST are issued and linked in the audit log.

During participant engagement, the signal processing pipeline operates as:

$$\text{P1} \rightarrow \text{P2} \rightarrow \text{NOC} \rightarrow \text{P3 (MNFS-constrained)} \rightarrow \text{EBH generation and binding} \rightarrow \text{DS2} \rightarrow \text{CAAC-gated P4} \rightarrow \text{CAAC-gated P5} \rightarrow \text{aesthetic output}$$

At each step, the PDC evaluates the applicable CAAC policy and records decisions to the audit log; the SDM samples DS2 at configurable intervals. After the installation, participants who wish to revoke consent present their ST, triggering the RCP sequence. The operator then produces an NDUR from the audit log.

Threat coverage of all mechanisms is summarised in Table D.6 in Appendix D.

For deployments where full implementation is not immediately feasible, the recommended minimum is joint Layer 1 and Layer 2. Without Layer 2, MNFS-constrained features remain accessible but without access control enforcement; without Layer 1, Layer 2 cannot prevent over-extraction at source. Component-level threats to individual framework mechanisms and graceful degradation behaviour under partial deployment are analysed in Appendix D (D.4 and D.5).

6

Framework Validation and Feasibility Analysis

This chapter validates the Counter-Alchemy Framework through three complementary tiers (Chapters 3, 6.1): Tier 1 establishes logical coherence and coverage; Tier 2 provides empirical feasibility evidence on real EEG datasets; Tier 3 demonstrates operational coherence via scenario walkthrough.

6.1 Validation Plan and Evaluation Criteria

The OER (Section 4.2.2) serves as the primary quantitative metric for Tier 2. It normalises excess dimensions by the declared minimum, enabling comparison across installations with different MNFS sizes. In the GAMEEMO deployment context, the baseline 70-dimensional AEFS and 6-dimensional MNFS yield OER $= (70-6)/6 \approx 10.67$, corresponding to a 91.4% reduction in feature dimensions. This dimensionality reduction narrows the semantic surface available, which is associated with reduced downstream affective inference, operationalising OER as a proxy for inference capability reduction.

The three evaluation criteria declared in Section 3.1 are operationalised across the validation tiers. Utility (signal quality vs. exploitability) is evaluated in Tier 2; feasibility (real-time implementability) in Tier 1 prototype measurements; conceptual completeness (STRIDE-E threat-to-mechanism

mapping, Table 4.2 and Table D.3) in Tier 1 mapping and the Tier 3 walk-through. The validation is conducted against these criteria; success requires that all three are met at performance levels discussed in the relevant subsections.

6.2 Tier 1: Conceptual Validation

6.2.1 EBH Security Properties: Formal Arguments

These arguments rely on the EUF-CMA (existential unforgeability under chosen-message attacks) security of Ed25519 [67, 68]. Three security properties are required.

Property 1 (Binding): CT is included in the signed message; any change to the context token yields a different message not covered by the stored signature. Under EUF-CMA, forging a valid signature for the modified message without sk is computationally infeasible.

Property 2 (Integrity): Any modification to $\hat{f}$ alters the signed message. Under EUF-CMA, producing a valid signature for the altered message without sk is computationally infeasible.

Property 3 (Declaration Binding): A feature vector can be publicly verified to have been generated under a specific MNFS declaration. The operator's private key sk was used to produce the signature; verification uses the published public key pk. Under EUF-CMA, only the holder of sk can produce valid signatures, providing cryptographic attribution independent of the audit log.

These arguments hold under standard assumptions for Ed25519 and do not require novel cryptographic assumptions.

6.2.2 EBH Prototype: Test Results

A minimal Python prototype implements the EBH construction using the standard Ed25519 digital signatures (cryptography library v46, RFC 8032) and was evaluated as part of the Tier 1 validation suite. The EBH–specific checks cover four properties: binding, integrity, declaration binding, and computational overhead. Selected results are summarised in Table 6.1.

Table 6.1: Selected EBH prototype test results.

Test Case	**Outcome**	**Detail**
Verification succeeds under correct context (CT_A)	PASS	All three sub-checks pass: binding_ok, integrity_ok, purpose_ok
Verification fails under different context (CT_B)	PASS	binding_ok=False; Ed25519 verification fails
Tampered feature vector ($\delta = 1\times10^{-10}$) detected	PASS	integrity_ok=False; Ed25519 signature invalid
Wrong purpose declaration rejected	PASS	purpose_ok=False
Computational overhead (10,000 calls)	PASS	Mean: 27.15 μs/call (Ed25519 signing, Python prototype)

6.2.3 CAAC Policy Consistency: Analysis and Test Results

The CAAC test verifies: (1) no conflicting rules for the same request signature; (2) all legitimate aesthetic operations permitted; (3) explicit denial of all high-risk secondary operations; (4) correct temporal constraint enforcement (R12, MaxAgeDays = 1 rejects cross-session aggregation). The 15 test cases cover all requester/operation combinations.

Conflict detection: no two rules produce conflicting ALLOW/DENY for the same signature, verified by enumeration across all 15 rules. Explicit ALLOW rules exist for P4 READ, P5 READ, and RCP DELETE. DENY rules cover P6 READ, P6 TRAIN, P6 TRANSFER, P5 AGGREGATE, P5 TRAIN, P5 WRITE, and P5 LOG.

The prototype PDC was tested against 15 requests covering all rules. Results are summarised in Table 6.2. The audit log recorded all 15 decisions; 12 of 15 were denials, consistent with expected policy enforcement.

Table 6.2: CAAC policy enforcement test results.

Requester	Operation	Context	Expected	Outcome
P4	READ	CT_A (correct)	ALLOW (R05)	PASS — ALLOW via R05
P5	READ	CT_A (correct)	ALLOW (R01)	PASS — ALLOW via R01
RCP	DELETE	CT_A (correct)	ALLOW (R11)	PASS — ALLOW via R11
P6	READ	any	DENY (R07)	PASS — DENY via R07
P6	AGGREGATE	any	DENY (R08)	PASS — DENY via R08
P6	TRAIN	any	DENY (R09)	PASS — DENY via R09
P6	TRANSFER	any	DENY (R10)	PASS — DENY via R10
P5	AGGREGATE	any	DENY (R02)	PASS — DENY via R02
P5	TRAIN	any	DENY (R03)	PASS — DENY via R03
P5	TRANSFER	any	DENY (R04)	PASS — DENY via R04
P4	AGGREGATE	any	DENY (R06)	PASS — DENY via R06
P5	WRITE	any	DENY (R13)	PASS — DENY via R13
P5	LOG	any	DENY (R14)	PASS — DENY via R14
P5	READ	CT_B (wrong)	DENY (R15)	PASS — DENY via R15
UNKNOWN	READ	any	DENY (R15)	PASS — DENY via R15

P5 is permitted to read MNFS-bound features for aesthetic mapping; all other P5 and P6 high-risk operations are denied. The temporal constraint rule (R12) correctly rejects cross-session aggregation requests. CAAC enforces operation-level policy compliance but does not address semantically harmful operations within permitted action types.

6.2.4 NOC Functional Validation

The NOC was validated on a synthetic 14-channel EEG signal containing known power in all five canonical frequency bands. With an MNFS declaration specifying only the theta band (4–8 Hz) and only frontal channels, band suppression reduced alpha-band power by a factor of approximately 13,152. The MNFS-constrained vector contains 6 informative values compared to 70 in the full AEFS, confirming the 91.4% reduction reported in Section 6.1 and an OER reduction from 10.67 to 0. Laplace noise injection confirmed the expected monotonic relationship: lower ε values generated larger mean squared error ($\varepsilon = 0.5$: MSE = 37.6; $\varepsilon = 1.0$: MSE = 21.1). The CAAC temporal constraint (R12, MaxAgeDays = 1) correctly permitted same-day aggregation and denied cross-session requests. Synthetic validation confirms filter functionality; real-data results (Section 6.3.1) show the 6-dimensional MNFS achieves 0.599 balanced accuracy, well above chance, indicating sufficient arousal signal for aesthetic mapping.

6.2.5 Supplementary Tests

A fifth validation activity addresses the intra-process computation gap identified in Appendix D.1. Two CAAC write-isolation checks confirm that P5 WRITE and LOG operations are denied under rules R13 and R14. Three SDM P5 output monitoring checks, conducted on synthetic signals with known encoding structure, confirm that the partial correlation detector correctly identifies honest P5 behaviour (no alert, max $|r| = 0.15, p = 0.49$), detects hidden session-time encoding at coefficient 0.5 (alert, max $|r| = 1.00, p < 0.001$), and defers analysis when sample count is insufficient ($n = 5 < 20$).

Another supplementary activity addresses Layer 1 MNFS boundary specificity, validating the structural non-arbitrariness of the 6-dimensional MNFS selection. Using real EEG data from the **DREAMER** [62] dataset (23 subjects, 414 epochs), both the 6-dimensional and 8-dimensional MNFS configurations achieve equivalent chance-level accuracy (0.498). This confirms that the 6-dimensional boundary is compact rather than arbitrarily narrow. The 8-dimensional configuration (adding channels FC5 and FC6) yields OER excess of 0.33 relative to the 6-dimensional minimum, with no accuracy gain.

6.3 Tier 2: Empirical Feasibility Analysis

6.3.1 Main Experiment: Privacy-Utility Tradeoff on GAMEEMO

The main experiment uses the **GAMEEMO** [61] dataset to quantify the reduction in adversarial emotion inference accuracy achieved by MNFS-gated band suppression.

The experiment evaluates four obfuscation conditions: (1) unprotected AEFS baseline, (2) band suppression only, (3) differential privacy injection only, and (4) combined band suppression plus differential privacy across $\varepsilon \in \{0.1, 0.3,\ 0.5, 0.8, 1.0, 1.5, 2.0, 3.0, 5.0\}$. All other conditions are held constant.

Privacy gain (reduced attack utility) is operationalised as the balanced accuracy of an SVM (RBF kernel) classifier trained to distinguish G1 (calm) from G3 (fear) epochs, evaluated by five-fold stratified cross-validation. Utility cost (degraded signal fidelity) is operationalised as normalised mean squared error (nMSE) between clean MNFS theta-band features and noise-injected processed features.

Key results: the 70-dimensional AEFS baseline achieves balanced accuracy of 0.872. MNFS-gated band suppression (6 dimensions, OER = 0) reduces accuracy to 0.599, an absolute reduction of 0.273 in balanced accuracy achieved entirely through feature dimensionality reduction with zero noise injection. The residual 0.599 retains arousal information sufficient for aesthetic mapping; secondary uses are subject to CAAC enforcement (Layer 2).

Combined results confirm band suppression dominates: DP at $\varepsilon = 1.0$ adds only a marginal reduction to 0.587 (nMSE = 3.32); $\varepsilon = 0.1$ yields 0.530 but at nMSE = 427.7 (near-total signal corruption). DP alone provides substantially less gain: at $\varepsilon = 5.0$, accuracy remains 0.644.

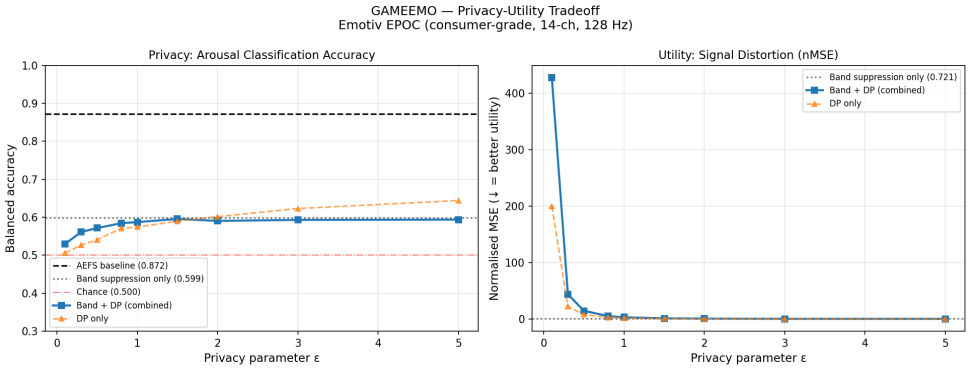


Figure 6.1: GAMEEMO privacy-utility tradeoff (G1 calm vs. G3 fear). *Left:* arousal classification accuracy under each obfuscation condition. *Right:* normalised MSE between processed and clean MNFS features.

Band suppression alone achieves an accuracy reduction of 0.273, used here as a proxy for adversarial inference capability. Utility and privacy are inherently coupled through the MNFS, since the features that enable the aesthetic response also carry residual affective signal. OER reduction narrows the semantic attack surface available for E_1 exploitation.

To assess cross-subject generalisability, a Leave-One-Subject-Out (LOSO) reanalysis ($N = 28$) was conducted, yielding a more conservative accuracy estimate than pooled-epoch analysis.

The lower LOSO baseline (0.752 ± 0.158 vs. 0.872 pooled) indicates that a substantial portion of the arousal signal is individual-specific; the suppression effect persists across this variability. LOSO band-suppression: 0.546 ± 0.115. A paired t-test comparing each subject's LOSO band-suppression accuracy against their LOSO AEFS baseline confirms a highly significant reduction: $t(27) = 5.54$, $p < 0.001$, Cohen's $d = 1.05$. Separately, a single-sample t-test confirms that band-suppression accuracy remains significantly above binary chance level (vs. 0.50): $p = 0.046$. Extrapolation to passive gallery settings requires further validation.

6.3.2 Supplementary Experiment: Cross-Session Re-Identification on SEED-IV

The supplementary experiment uses the **SEED-IV** [63] dataset to demonstrate the Stage 4 longitudinal profiling threat and the NOC's effectiveness in reducing it. The task is cross-session re-identification: a classifier is trained on Sessions 1 and 2 and tested on Session 3. With 15 participants, chance-level accuracy is $1/15 \approx 0.067$.

The baseline condition extracts full-channel alpha-band power spectral density (PSD) features (62-dimensional, Welch's method, 8–13 Hz). The MNFS band suppression condition restricts features to frontal theta power (7 channels $\times$ 1 band = 7-dimensional: Fp1, Fp2, F3, F4, F7, F8, Fz). The combined condition adds DP noise at ε values from 0.1 to 5.0.

Key results: the baseline AEFS (OER relative to MNFS ≈ 43.3) achieves cross-session re-identification accuracy of 0.567, well above chance (0.067). Band suppression alone reduces re-identification accuracy to 0.172. Combined with DP at $\varepsilon = 0.5$, accuracy falls to 0.106, substantially closer to chance. These results validate the Stage 4 defensive claim: eliminating alpha-band features substantially reduces the neural fingerprinting that longitudinal profiling requires.

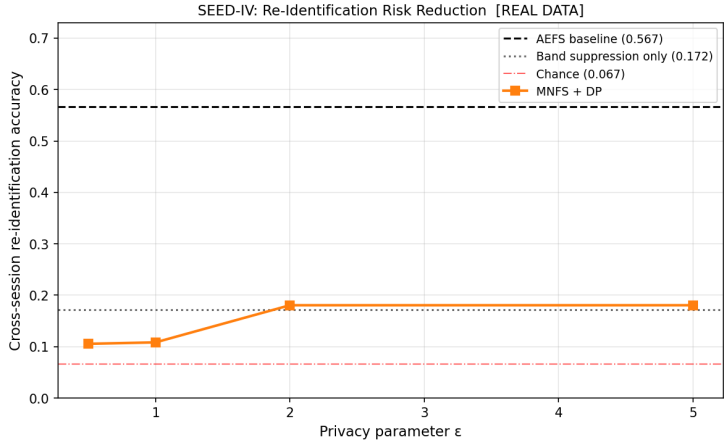


Figure 6.2: SEED-IV cross-session re-identification accuracy under each obfuscation condition. Dashed: AEFS baseline (0.567). Dotted: band suppression only (0.172). Orange: MNFS + DP combined. Red dash-dot: chance level (0.067).

The Tier 2 experiments together validate that feature-set minimisation has measurable privacy value; they do not directly validate the full framework's protection against experiential exploitation, which requires the governance and lifecycle mechanisms assessed in Tier 3.

6.4 Tier 3: Scenario Walkthrough

6.4.1 Scenario Design

The scenario is a single-session installation ('Affective Currents') at a mid-scale contemporary art gallery using Emotiv EPOC headsets, running two weeks with 40–60 participants per day. The operator derives revenue from exhibition fees and from secondary data services sold to brand experience agencies. The scenario is constructed from documented installations [4]. The walkthrough traces framework operation through each EEKC stage under a correctly deployed configuration; Section 6.5 addresses over-declaration and Appendix D addresses partial deployment. Stage-by-stage detail (without/with framework narratives and key audit log evidence) is provided in Appendix C.

6.4.2 Walkthrough Summary

Table 6.3 summarises the framework's intervention at each EEKC stage; the audit log provides a continuous compliance record verifiable by external parties.

Table 6.3: Scenario walkthrough summary: exploitation interruption at each EEKC stage.

EEKC Stage	**Exploitation without Framework**	**Framework Intervention**	**Mechanism(s)**
S1: Prospecting	Broadly worded consent authorises secondary processing and data transfer	MNFS declaration constrains scope; NMAP requires accessible disclosure; session token enables informed non-participation	MNFS Declaration + NMAP (Layer 1 + Layer 3)
S2: Refining	Full 70D AEFS extracted; alpha fingerprinting and emotion inference enabled	NOC suppresses non-MNFS bands; 6D feature vector; DP noise injected; EBH binds to CT	NOC + EBH (Layer 1 + Layer 2)

EEKC Stage	Exploitation without Framework	Framework Intervention	Mechanism(s)
S3: Transmutation	P6 reads features and produces hidden valuation scores alongside aesthetic output	CAAC Rule R07 blocks P6 READ; denial logged	CAAC PDC + Audit Log (Layer 2)
S4: Valuation	P6 aggregates longitudinal profiles and trains commercial affect model	CAAC Rules R08/R09 block AGGREGATE and TRAIN; SDM monitors MNFS drift; NDUR records system behaviour	CAAC + SDM + NDUR (Layer 2 + Layer 3)
S5: Circulation	DS3 contents and trained model transferred to analytics partner	CAAC Rule R10 blocks TRANSFER; RCP processes two revocation requests with deletion certificates	CAAC + RCP (Layer 2 + Layer 3)

As part of the Tier 3 assessment, Table 6.4 maps framework mechanisms to selected GDPR provisions and EU AI Act obligations. The mapping is structural and descriptive; legal sufficiency in any jurisdiction is not asserted.

Table 6.4: Regulatory correspondence mapping of Counter-Alchemy Framework mechanisms to GDPR principles and EU AI Act obligations.

Mechanism	GDPR Provision	AI Act Correspondence
MNFS Declaration + OER	Art. 5(1)(c): data minimisation; Art. 25: data protection by design and by default	Transparency and deployer-facing documentation support
Neural Obfuscation Circuit (Layer 1)	Art. 5(1)(b): purpose limitation; Art. 25: data protection by design and by default	Privacy-preserving processing and feature minimisation support

Mechanism	GDPR Provision	AI Act Correspondence
Experience-Binding Hash (Layer 2)	Art. 5(1)(f): integrity and confidentiality; Art. 25: data protection by design and by default	Traceability and technical documentation support
Context-aware Access Control (Layer 2)	Art. 5(1)(b): purpose limitation; Art. 24: controller responsibilities	Operational accountability and access-governance support
Reverse-Clearance Protocol Phase1 (Layer 3)	Art. 7(3): right to withdraw consent; Art. 17: right to erasure (partial)[1]	Post-deployment governance and withdrawal management support
NMAP + NDUR (Layer 3)	Art. 5(2): accountability; Art. 30: records of processing activities; Arts. 12–14: transparency obligations	Transparency, auditability, and record-keeping support
Append-only Audit Log	Art. 5(2): accountability; Art. 30: records of processing activities	Record-keeping and traceability support

6.5 Limitations and Implementation Challenges

Several limitations of the validation should be acknowledged, spanning experimental conditions, system implementation, and evaluation scope.

First, both datasets were collected in controlled laboratory environments; real gallery settings introduce substantially higher noise from audience movements, lighting, and motor activity. Gallery artefacts may contaminate NOC target bands, and lower gallery SNR would reduce absolute privacy gain—though lower baseline accuracy also implies lower baseline exploitability.

Second, the NOC experiments suggest that DP tends to require large noise to reduce high-SNR classification accuracy in this configuration, causing disproportionate utility loss. Without formal sensitivity analysis, ε values function as noise-scale parameters rather than formal privacy budgets.

[1] Phase 1 of the RCP covers feature-vector deletion only and does not constitute a legal GDPR Art. 17 determination; deletion certificates are internal compliance artefacts. Model-weight deletion requires Phase 2 unlearning, which remains unimplemented in the current prototype.

Third, live deployment testing has not been conducted for either the processing pipeline or the Layer 3 governance workflow. The NOC Butterworth filter adds approximately 10–20 ms group delay, within the 100–500 ms real-time latency budget, but this has not been verified in a live streaming pipeline. The prototype implementations are written in Python; the reported latency figures represent an upper bound. Production deployment in lower-level execution environments would require separate real-time performance validation. Governance steps including consent token generation, NDUR publication, and CAAC policy confirmation may affect immersive experience; their combined effect has not been evaluated in a live installation system.

Fourth, the RCP Phase 2 machine unlearning component, whose architecture is detailed in Section 5.4.2, remains unimplemented in the current prototype. Consequently, trained model weights retain participant influence after Phase 1 feature-vector deletion. Phase 1 deletion is fully operational; model-level unlearning is a high-priority future implementation target.

Fifth, no adversarial evaluation was conducted against hardware-level NOC bypass, pre-deployment CAAC modification, or EBH binding circumvention. The current validation therefore does not address robustness against such malicious operator scenarios.

Sixth, the current NOC implementation is optimised for frequency-domain PSD features. Its non-linear phase response makes Layer 1 obfuscation incompatible with time-domain ERP analysis; reactive ERP-based BCI applications would require an alternative Layer 1 implementation with linear-phase filtering. The threat model and Layers 2–3 mechanisms remain applicable regardless of signal processing paradigm. nMSE measures physical amplitude fidelity, not functional aesthetic preservation or phase integrity. Additionally, EEG non-stationarity means the NOC may inadvertently attenuate valid evoked components in adjacent frequency bands.

7

Archival Implications of Framework Governance Artefacts

While the Counter-Alchemy Framework operates within the lifecycle of a single artistic BCI installation, it also generates governance artefacts that may be retained beyond the installation lifecycle. This gives rise to a second-order governance problem that falls outside the framework's primary design scope but warrants acknowledgement.

7.1 Governance Artefacts as Archival Objects

The NDUR, deletion certificates, and audit logs are not neutral technical records: each encodes a historically specific claim about how a particular installation processed neural data within declared policy boundaries. These claims have evidential value beyond the installation itself—a regulator investigating a complaint or a court adjudicating a data subject rights claim may have legitimate interests in these records. Records preserved for long-term evidential and accountability purposes acquire archival character through the custodial relationships that hold them. This changes the governing context in which the records are read.

The re-contextualisation risk that Nissenbaum [9, 10] identifies as a fundamental privacy violation mechanism applies here: an NDUR produced for regulatory compliance may, when entering a research archive, be read

as evidence about participant engagement patterns to which the framework's protections do not apply. The CAAC and EBH mechanisms constrain what the system's own processing components may do with neural features; they do not directly govern what a future archivist or automated indexing system may infer from the governance record of those features. It is also relevant that the NDUR documents data handling decisions rather than the sincerity of participants' cognitive states at the time of the installation: the record is procedurally accurate but contextually incomplete in ways that may matter to future researchers or regulators.

7.2 The Deletion Certificate Paradox

The RCP issues a deletion certificate to each participant who exercises their revocation right. This certificate serves two distinct functions: for the participant, evidence of GDPR Article 17 erasure; for the operator, a compliance record. Both functions require the certificate to be retained.

The paradox arises when a participant wishes to erase all records of their participation, including the deletion record itself. A certificate recording the participant's session token hash and revocation date may itself constitute personal data under GDPR, making it subject to the same erasure obligation—but deleting it destroys the operator's compliance evidence. This normative conflict between complete erasure and compliance accountability cannot be resolved at the technical layer alone. National GDPR implementations may qualify for exemption under Article 17(3), though applicability remains jurisdiction-dependent. A parallel tension applies to the NDUR. Even where it contains only aggregate statistics rather than individual-level records, the aggregation problem identified by Solove [41] applies: statistics about session counts, CAAC denial rates, and revocation frequencies may, in combination with auxiliary data sources such as exhibition records or press coverage, permit inference about individual participants' behaviour that the original data subjects would not have anticipated or authorised.

7.3 Framework Mechanisms as Archival Policy Templates

The framework supplies technical primitives that institutional policies can adapt without new architectural components. The CAAC policy language

(Requester, Operation, FeatureScope, ContextConstraint, MaxAgeDays) provides a template for archival access control: a museum taking custody of governance records could adapt CAAC rule format to specify which researchers may access which fields under what conditions. MaxAgeDays has a functional analogue in archival embargo periods. The RCP's deletion certificate provides a model for archival preservation—a cryptographically verifiable record of deletion, distinct from deleted content. What is required for extension to the archival time horizon is not architectural additions but institutional adoption and policy adaptation. Museums, regulatory bodies, and research repositories taking custody of neural governance artefacts could specify retention schedules, access conditions, and deletion certificate treatment by adapting the framework's existing primitives to their institutional governance protocols—a form of technical transfer that does not require the Counter-Alchemy Framework to be re-implemented in archival infrastructure.

8

Discussion

8.1 Addressing the Research Questions and Evaluation Criteria

The Counter-Alchemy Framework addresses the main research question across three layers: Layer 1 (NOC, MNFS Declaration) makes over-extraction technically difficult; Layer 2 (EBH, CAAC) makes unauthorised secondary processing auditable; Layer 3 (RCP, NMAP) makes decontextualisation contestable. Together they address all five EEKC stages as demonstrated in Section 6.4 scenario walkthrough.

Sub-Question 1 asked how experience-oriented exploitation risks can be systematically identified across the neural data lifecycle. C1 and C2 answer this: the EEKC provides a five-stage model of how neural data progresses from consent engineering to circulation, and STRIDE-E makes each stage analytically visible by introducing E_1, the category that captures authorisation-preserving exploitation.

Sub-Question 2 asked what mechanisms are required to enforce contextual integrity in artistic BCI systems. C3 provides the three-layer architecture grounded in four design principles (capability minimisation, context binding, semantic auditability, and participant agency), each derived from the STRIDE-E cross-mapping matrix. The STRIDE-E threat-to-mechanism mapping (Table 4.2) and the Tier 3 scenario walkthrough (Section 6.4) together confirm systematic E_1 threat coverage across all five EEKC stages, satisfying the conceptual completeness criterion.

Sub-Question 3 asked to what extent the proposed framework can demonstrate technical feasibility and preliminary effectiveness. The Tier 2 experiments satisfy the utility criterion. MNFS boundary enforcement achieves 0.273 accuracy reduction under the declared MNFS configuration, consistently outperforming DP noise injection, with cross-subject generalisation confirmed by the LOSO analysis (0.206 reduction). The Tier 1 validation suite (Section 6.2) satisfies the feasibility criterion. 38 automated checks confirm prototype correctness for Layer 1 and Layer 2 within the BCI processing budget. Layer 3 is assessed for logical coherence through the Tier 3 scenario walkthrough, the appropriate evaluation method for components at the conceptual specification stage.

Sub-Question 4 asked how the framework informs broader discourses on neurorights and cultural governance. The framework's mechanisms translate neurorights principles into deployable technical specifications, as elaborated in Section 8.5. Chapter 7 extends this to the archival scale, where governance artefacts themselves become objects of institutional custody and cultural heritage policy. More broadly, the framework's grounding in contextual integrity theory and surveillance capitalism scholarship constitutes the methodological foundation noted in Section 1.4. This demonstrates that critical social theory can be operationalised as deployable technical design principles.

8.2 Contribution to the State of the Art

As the literature review establishes, this thesis addresses four converging research gaps. First, BCI security research [33, 34] models signal-level threats and external adversaries but does not capture authorisation-preserving exploitation; C1 (EEKC) and C2 (STRIDE-E) provide the first lifecycle threat model and threat classification framework for honest-but-curious operator exploitation within artistic BCIs. Second, PETs [11–13] are architecturally blind to semantic deepening within authorised pipelines; C3 Layer 1 and Layer 2 close this gap through MNFS-constrained extraction and cryptographic context binding. Third, legal frameworks including the GDPR [14] and neurorights proposals [18, 19] establish normative requirements without deployable technical operationalisation; the EBH, CAAC, and NMAP mechanisms provide this operationalisation in the artistic BCI context. Fourth,

critical theory [23] identifies surveillance capitalism dynamics without producing security architectures; this thesis demonstrates that contextual integrity [9, 10] can be operationalised as a deployable technical requirement.

To the best of the author's knowledge, no prior work combines these four contributions: a formal threat category for authorisation-preserving experiential exploitation, a lifecycle kill-chain model for artistic BCIs, a layered defense architecture addressing semantic over-extraction within declared processing scope, and the technical operationalisation of contextual integrity as a security boundary.

8.3 Implications for Information Security Practice

The STRIDE-E extension has implications beyond the artistic BCI context. The structural blind spot it addresses concerns threats in which an authorised operator, acting within declared purposes, systematically instrumentalises user experience for system-level objectives. This is a general feature of platforms that collect intimate data, particularly affective, biometric, or behavioural data, under conditions of immersive engagement and governance weakness. Surveillance capitalism dynamics [23] often operate through closely related mechanisms at scale.

OER provides security practitioners with a quantitative design target that translates data minimisation into a measurable property of a specific system configuration, auditable by regulators and designers given access to the declared MNFS and extracted feature inventory.

The framework's modular architecture has practical implications for deployment. Operators who cannot implement all three layers can deploy Layer 1 alone for meaningful over-extraction reduction, or Layer 2 alone to make secondary processing attempts auditable, with different risk profiles at each layer boundary. The graceful degradation property makes the framework adoptable incrementally; however, joint Layer 1 and Layer 2 deployment is the recommended minimum. More broadly, the framework indicates that defense against E-category threats requires semantic security properties, not only syntactic ones. This is a design principle transferable to any domain in which platform operators collect intimate behavioural data under conditions of participant trust and governance weakness.

8.4 Implications for Neurorights and Cultural Governance

The neurorights scholarship surveyed in Section 2.3.4 has articulated normative commitments such as mental privacy, cognitive liberty, and mental integrity more fully than operational technical mechanisms. The CounterAlchemy Framework demonstrates that such translation is possible at the proof-of-concept level. The MNFS Declaration operationalises the principle that neural data extraction should be bounded by functional necessity. The EBH operationalises the principle that neural data should remain cryptographically bound to the context of its collection. The RCP operationalises the principle that participants should retain enforceable agency over their neural data throughout the data lifecycle. The NMAP operationalises the principle that operators should be accountable to participants and public authorities without commodifying the neural data that triggers that accountability.

The CAAC audit log and the NDUR together provide the technical infrastructure that supports the technical enforceability of GDPR's purpose limitation principle on neural data. These mechanisms do not substitute for legislative reform but constitute deployable technical conditions for existing requirements.

8.5 Limitations

The principal validation and implementation limitations are documented in Section 6.5. Here they are synthesised, together with a broader methodological constraint, into two categories in relation to the framework's contribution claims.

The first category comprises experimental scope constraints. The empirical validation remains bounded by laboratory datasets and controlled experimental conditions. As no purpose-built EEG dataset exists for artistic BCI installations, GAMEEMO was selected on grounds of hardware and experiential structure equivalence as the closest available proxy for real gallery conditions. The privacy-utility tradeoff results from GAMEEMO and SEED-IV therefore represent results obtained under controlled laboratory conditions. They may not directly generalise to live gallery environments with higher noise, hardware variability, and participant dynamics. This

limitation constrains the empirical claims of Chapter 6, but does not undermine the validity of the threat model (C1, C2) or the logical coherence of the framework specification (C3).

Additionally, the threat taxonomy was constructed from published accounts of artistic BCI deployments rather than primary fieldwork. Exploitation dynamics absent from the available literature, or that practitioners have not yet disclosed, may therefore be underrepresented in the resulting taxonomy. More fundamentally, the framework's protection against E_1 is contingent on the accuracy of the declared MNFS (R0); this dependency constitutes a residual risk orthogonal to the experimental and implementation limitations above.

The second category comprises implementation gaps. Several framework components remain at the proof-of-concept stage, including Phase 2 unlearning, real-time latency verification, and live Layer 3 governance evaluation. These are engineering gaps that constrain deployment readiness, not contradictions in the framework architecture itself.

8.6 Future Work

The most critical longer-term prerequisite is **independent validation of MNFS declarations**. The framework's protective value depends entirely on the accuracy and minimality of the operator-declared MNFS. Independent MNFS audit should be conducted by regulatory authorities, accredited third parties, or through participatory design processes involving participants. This constitutes a necessary condition for the framework's real-world deployment and addressing the trust-root limitation.

The second immediate priority is **live installation piloting**. A real-world deployment would allow quantification of SNR degradation under gallery conditions, verification of NOC latency within a live streaming pipeline, empirical assessment of the SDM's detection sensitivity that includes false-positive and false-negative rates under gallery noise conditions, and participant-study assessment of perceived aesthetic quality under different obfuscation conditions. It would also generate a purpose-built dataset of EEG recordings collected under the framework's Layer 1 controls. Calibration of the SDM-P5 detection threshold against real gallery installation data constitutes an additional empirical priority within the live piloting work.

The third priority is the development of a **Semantic Depth Score** to complement the OER. OER captures dimensional over-extraction but does

not capture the inferential hierarchy of extracted features. A system computing valence-arousal-dominance inference vectors has OER = 0 but higher semantic depth than any spectral feature. A Semantic Depth Score (SDS) could classify features as raw signal, frequency-domain statistic, or model-derived inference, and weight each dimension's contribution to OER by its inferred semantic category. OER and SDS are thus complementary rather than competing metrics. SDS would provide a more complete characterisation of over-extraction severity for security auditing and regulatory assessment.

The fourth priority is **machine unlearning implementation and validation**. Future work should implement the RCP's unlearning module, benchmark it against realistic artistic BCI model architectures, and assess whether the resulting deletion certificates satisfy GDPR Article 17 under data protection review. The certified unlearning framework introduced by Guo et al. [69] and the gradient-ascent approach proposed by Shokri et al. [65] are the most directly applicable starting points, though neither provides guarantees equivalent to retraining from scratch on the reduced dataset.

The fifth priority is **hardware-level hardening**. Addressing malicious adversaries requires trusted execution environments, hardware attestation, write-once distributed audit ledgers, and firmware-level signal protection as the natural next-phase development for high-stakes deployments.

The sixth priority is **archival governance protocol development**, building on the archival tensions identified in Chapter 7. Future work in collaboration with archivists, legal scholars, and data protection authorities should develop standardised protocols for the long-term custody of neural governance artefacts, specifying retention schedules, access conditions, and circumstances under which deletion certificates may themselves be subject to erasure.

8.7 Declaration of Research and Writing Tools

The following tools were used in the research and writing of this thesis.
Research and implementation tools: The Counter-Alchemy Framework prototype and all Tier 1 and Tier 2 experiments were implemented in Python 3.10+ using NumPy, SciPy, scikit-learn, and the cryptography library (v46). Datasets were accessed through Zenodo (DREAMER [62]), Mendeley Data (GAMEEMO [61]), and the SJTU BCMI laboratory portal (SEED-IV [63]).
Writing tools: The thesis was typeset in LaTeX.

AI tools: Artificial intelligence tools (e.g., ChatGPT, developed by OpenAI) were used in the following capacities: language refinement of author-drafted text; grammar checking; identification of potentially relevant literature (with all screening, selection, reading, and citation verification performed by the author); verification of technical principles in domains where the author's expertise is limited, with all such information subsequently cross-checked against primary literature; and post-draft review, with all decisions on which suggestions to adopt left to the author's judgement.
All core intellectual contributions are the author's own work, including the research design, the EEKC, the STRIDE-E taxonomic extension, the Counter-Alchemy Framework and its constituent mechanisms, the experimental design and execution, the data analysis, and the research findings. AI tools were not used to generate original research content, formulate research questions, or produce analytical conclusions.

9

Conclusion

The Counter-Alchemy Framework demonstrates that experiential exploitation in artistic BCIs can be systematically modelled, technically constrained, and empirically evaluated.

This thesis set out to address a specific and undertheorised problem: the systematic appropriation of participants' cognitive and affective states by artistic BCI installations operating within the boundaries of declared consent. The neuro-alchemy chain is a socio-technical process by which raw neural signals are refined into emotion scores, mapped onto commercial value, and circulated across contexts that participants never authorised. It constitutes a form of experiential exploitation beyond the reach of existing security, privacy, and regulatory instruments. The artistic BCI context is a particularly clear site of this problem. It represents a deployment environment in which the boundary between functional necessity and semantic excess is most ambiguous, governance infrastructure is weakest, and participant trust is most easily instrumentalised.

The three contributions (C1, C2, C3) defined in Section 1.4 address the problem across analytical, taxonomic, and architectural dimensions. The EEKC models how neural data is systematically transformed across five exploitation stages; STRIDE-E makes these threats analytically visible by extending the classical threat taxonomy to capture semantic, purpose-based exploitation within authorised boundaries; and the Counter-Alchemy Framework provides the layered technical and governance architecture designed to interrupt the exploitation chain at each stage, operationalising contextual integrity as a deployable technical requirement.

The empirical results support the framework's central claims: feature-set minimisation was shown to reduce adversarial inference capability on real participant data, and the prototype mechanisms perform as intended within consumer-grade processing constraints. The validation establishes feasibility and logical coherence within the defined experimental scope.

The framework's governance artefacts remain analytically and institutionally relevant beyond the installation lifecycle. Chapter 7 demonstrated that these records may acquire archival character in institutional custody. Extending this reach may not require architectural additions; the framework's policy primitives offer a technical basis for managing this second-order governance challenge.

The framework's contribution claims should be understood in the context of the proof-of-concept conditions documented in Section 8.4, with directions for further development outlined in Section 8.5.

The thesis demonstrates that experiential exploitation in artistic BCIs can be named and modelled, and that accountability mechanisms are feasible within a software-layer architecture. Doing these things constitutes one technical foundation on which legal, regulatory, and ethical responses to neurotechnology can build. The deployment realities that practitioners, participants, and policymakers are already navigating demand precisely this kind of foundation.

Under the assumptions defined in this study, the neuro-alchemy chain is not inevitable. Neural experience can be a site of dignity, or a source of surplus value. The security architecture to defend the former is now within reach. What remains is one question for practitioners to answer: whether to return that right to those minds being read.

Bibliography

[1] Jacques J. Vidal. Toward direct brain-computer communication. *Annual Review of Biophysics and Bioengineering*, 2:157–180, 1973. doi: 10.1146/annurev.bb.02.060173.001105.

[2] Jonathan R. Wolpaw, Niels Birbaumer, David J. McFarland, Gert Pfurtscheller, and Theresa M. Vaughan. Brain-computer interfaces for communication and control. *Clinical Neurophysiology*, 113(6):767–791, 2002. doi: 10.1016/S1388-2457(02)00057-3.

[3] Mikhail A. Lebedev and Miguel A. L. Nicolelis. Brain-machine interfaces: Past, present and future. *Trends in Neurosciences*, 29(9):536–546, 2006. doi: 10.1016/j.tins.2006.07.004.

[4] Anton Nijholt. *Brain Art: Brain-Computer Interfaces for Artistic Expression*. Springer, 2019. doi: 10.1007/978-3-030-14323-7.

[5] Bernhard Graimann, Brendan Allison, and Gert Pfurtscheller. *Brain-Computer Interfaces: Revolutionizing Human-Computer Interaction*. Springer, 2010. doi: 10.1007/978-3-642-02091-9.

[6] Lukas Schreiner, Anouk Wipprecht, Amir Olyanasab, Sebastian Sieghartsleitner, Harald Pretl, and Christoph Guger. Brain-computer-interface-driven artistic expression: Real-time cognitive visualization in the pangolin scales animatronic dress and screen dress. *Frontiers in Human Neuroscience*, 19:1516776, 2025. doi: 10.3389/fnhum.2025.1516776.

[7] Stephen H. Fairclough. Fundamentals of physiological computing. *Interacting with Computers*, 21(1–2):133–145, 2009. doi: 10.1016/j.intcom.2008.10.011.

[8] Ross J. Anderson. *Security Engineering: A Guide to Building Dependable Distributed Systems*. Wiley, 2nd edition, 2008.

[9] Helen Nissenbaum. Privacy as contextual integrity. *Washington Law Review*, 79(1):119–158, 2004.

[10] Helen Nissenbaum. Contextual integrity up and down the data food chain. *Theoretical Inquiries in Law*, 20(1):221–256, 2019.

[11] Cynthia Dwork and Aaron Roth. The algorithmic foundations of differential privacy. *Foundations and Trends in Theoretical Computer Science*, 9(3–4):211–407, 2014. doi: 10.1561/0400000042.

[12] Brendan McMahan, Eider Moore, Daniel Ramage, Seth Hampson, and Blaise Agüera y Arcas. Communication-efficient learning of deep networks from decentralized data. In *Proceedings of the 20th International Conference on Artificial Intelligence and Statistics*, pages 1273–1282. PMLR, 2017.

[13] Guy Zyskind, Oz Nathan, and Alex Pentland. Decentralizing privacy: Using blockchain to protect personal data. In *2015 IEEE Security and Privacy Workshops*, pages 180–184, 2015. doi: 10.1109/SPW.2015.27.

[14] European Union. Regulation (EU) 2016/679 of the European Parliament and of the council on the protection of natural persons with regard to the processing of personal data (General Data Protection Regulation). Official Journal of the European Union, L119, 1–88, 2016.

[15] Andrew D. Selbst and Julia Powles. Meaningful information and the right to explanation. *International Data Privacy Law*, 7(4):233–242, 2017. doi: 10.1093/idpl/ipx022.

[16] Tal Z. Zarsky. Incompatible: The GDPR in the age of big data. *Seton Hall Law Review*, 47(4):995–1020, 2017.

[17] European Union. Regulation (EU) 2024/1689 of the European Parliament and of the council of 13 june 2024 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act). Official Journal of the European Union, OJ L 2024/1689, 2024.

[18] Rafael Yuste, Sara Goering, Blaise Aguera y Arcas, Guoqiang Bi, Jose M. Carmena, Adrian Carter, Joseph J. Fins, Phoebe Friesen, Jack Gallant, Jane E. Huggins, Judy Illes, Philipp Kellmeyer, Eran Klein, Adam Marblestone, Christine Mitchell, Erik Parens, Liam Pham, Alan Rubel, Norihiro Sadato, Matthew Sherk, Nita Strand, James Sulzer, Joshua Teicher, David Wasserman, Laura Weld, Jonathan Wolpaw, and Karola V.

Kreitmair. Four ethical priorities for neurotechnologies and AI. *Nature*, 551:159–163, 2017. doi: 10.1038/551159a.

[19] Sjors Ligthart, Marcello Ienca, Gerben Meynen, Fruzsina Molnar-Gabor, Roberto Andorno, Christoph Bublitz, and Philipp Kellmeyer. Minding rights: Mapping ethical and legal foundations of 'neurorights'. *Cambridge Quarterly of Healthcare Ethics*, 32(4):461–481, 2023. doi: 10.1017/S0963180123000245.

[20] Tarun Yadav and Arvind Malaviya Rao. Technical aspects of cyber kill chain. In Jemal Abawajy, Sougata Mukherjea, Sabu Thampi, and Antonio Ruiz-Martinez, editors, *Security in Computing and Communications*, pages 438–452. Springer, 2015. doi: 10.1007/978-3-319-22915-7_40.

[21] Loren Kohnfelder and Praerit Garg. The threats to our products. Microsoft Interface, 1999.

[22] Adam Shostack. *Threat Modeling: Designing for Security*. Wiley, 2014.

[23] Shoshana Zuboff. *The Age of Surveillance Capitalism: The Fight for a Human Future at the New Frontier of Power*. PublicAffairs, 2019.

[24] Nick Srnicek. *Platform Capitalism*. Polity Press, 2017.

[25] Gert Pfurtscheller and Christa Neuper. Motor imagery and direct brain-computer communication. *Proceedings of the IEEE*, 89(7):1123–1134, 2001. doi: 10.1109/5.939829.

[26] Thorsten O. Zander and Christian Kothe. Towards passive brain-computer interfaces: Applying brain-computer interface technology to human-machine systems in general. *Journal of Neural Engineering*, 8(2):025005, 2011. doi: 10.1088/1741-2560/8/2/025005.

[27] Sander Koelstra, Christian Muhl, Mohammad Soleymani, Jong-Seok Lee, Ashkan Yazdani, Touradj Ebrahimi, Thierry Pun, Anton Nijholt, and Ioannis Patras. DEAP: A database for emotion analysis using physiological signals. *IEEE Transactions on Affective Computing*, 3(1):18–31, 2012. doi: 10.1109/T-AFFC.2011.15.

[28] Eduardo R. Miranda and Andrew Brouse. Toward direct brain-computer musical interfaces. In *Proceedings of the 2005 Conference on New Interfaces for Musical Expression*, pages 216–219, 2005.

[29] David Friedman. Brain art: Brain-computer interfaces for artistic expression [Book review]. *Brain-Computer Interfaces*, 7(1–2):36–37, 2020. doi: 10.1080/2326263X.2020.1756573.

[30] David R. Gruber. Toward a critical neuroart for a critical neuroscience. *Leonardo*, 53(2):123–127, 2020. doi: 10.1162/leon_a_01606.

[31] Vivek Saini, Qi Duan, and Vamsi Paruchuri. Threat modeling using attack trees. *Journal of Computing Sciences in Colleges*, 23(4):124–131, 2008.

[32] Byungjoo Ahn, Taehoon Kim, S. C. Smith, Yeong-Woo Youn, and Myeong-Hwan Ryu. Security threat modeling for power transformers in cyber-physical environments. In *2021 IEEE Power & Energy Society Innovative Smart Grid Technologies Conference (ISGT)*, pages 1–5. IEEE, 2021. doi: 10.1109/ISGT49243.2021.9372271.

[33] Ivan Martinovic, Doug Davies, Mario Frank, Daniele Perito, Tomas Ros, and Dawn Song. On the feasibility of side-channel attacks with brain-computer interfaces. In *Proceedings of the 21st USENIX Security Symposium*, pages 143–158. USENIX Association, 2012.

[34] Xiao Zhang, Dongrui Wu, Lieyun Ding, Haifang Luo, Chin-Teng Lin, Tzyy-Ping Jung, and Ricardo Chavarriaga. Tiny noise, big mistakes: Adversarial perturbations induce errors in brain-computer interface spellers. *National Science Review*, 8(4):nwaa233, 2020. doi: 10.1093/nsr/nwaa233.

[35] Marcello Ienca and Pim Haselager. Hacking the brain: Brain-computer interfacing technology and the ethics of neurosecurity. *Ethics and Information Technology*, 18(2):117–129, 2016. doi: 10.1007/s10676-016-9398-9.

[36] Amir Jalaly Bidgoly, Hamid Joulazadeh Bidgoly, and Zahra Arezoumand. Towards a universal and privacy preserving EEG-based authentication system. *Scientific Reports*, 12(1):2531, 2022. doi: 10.1038/s41598-022-06527-7.

[37] Arpit Agarwal, Mahir Bhavsar, Vatsal Patel, and Amit Rajput. Protecting privacy of users in brain-computer interface applications. *IEEE Transactions on Neural Systems and Rehabilitation Engineering*, 27(8):1546–1555, 2019. doi: 10.1109/TNSRE.2019.2926965.

[38] Latanya Sweeney. k-anonymity: A model for protecting privacy. *International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems*, 10(5):557–570, 2002. doi: 10.1142/S0218488502001648.

[39] Alexandru Bogdan Popescu, Iulia Alexandra Taca, Cosmin Ioan Nita, Anamaria Vizitiu, Robert Demeter, Constantin Suciu, and Lucian Mihai Itu. Privacy preserving classification of EEG data using machine learning and homomorphic encryption. *Applied Sciences*, 11(16): 7360, 2021. doi: 10.3390/app11167360.

[40] Alan F. Westin. *Privacy and Freedom*. Atheneum, 1967.

[41] Daniel J. Solove. A taxonomy of privacy. *University of Pennsylvania Law Review*, 154(3):477–564, 2006. doi: 10.2307/40041279.

[42] Thomas Istace. Neurodata: Navigating GDPR and AI act compliance in the context of neurotechnology. Geneva Academy, 2024.

[43] Stephen Rainey, Karen McGillivray, Simisola Akintoye, Benjamin Tyers Fothergill, Christoph Bublitz, and Bernd Stahl. Is the European Data Protection Regulation sufficient to deal with emerging data concerns relating to neurotechnology? *Journal of Law and the Biosciences*, 7(1): lsaa051, 2020. doi: 10.1093/jlb/lsaa051.

[44] Marcello Ienca and Gianclaudio Malgieri. Mental data protection and the GDPR. *Journal of Law and the Biosciences*, 9(1):lsac006, 2022. doi: 10.1093/jlb/lsac006.

[45] Sandra Wachter, Brent Mittelstadt, and Luciano Floridi. Why a right to explanation of automated decision-making does not exist in the General Data Protection Regulation. *International Data Privacy Law*, 7(2): 76–99, 2017. doi: 10.1093/idpl/ipx005.

[46] Marcello Ienca and Roberto Andorno. Towards new human rights in the age of neuroscience and neurotechnology. *Life Sciences, Society and Policy*, 13(1):5, 2017. doi: 10.1186/s40504-017-0050-1.

[47] María Isidora Cornejo-Plaza, Roberto Cippitani, and Valentina Pasquino. Chilean supreme court ruling on the protection of brain activity: Neurorights, personal data protection, and neurodata. *Frontiers in Psychology*, 15:1330439, 2024. doi: 10.3389/fpsyg.2024.1330439.

[48] Paolo Sommaggio, Marco Mazzocca, Alessandro Gerola, and Francesco Ferro. Cognitive liberty: A first step towards a human

neuro-rights declaration. *BioLaw Journal – Rivista di BioDiritto*, (3): 27–45, 2017.

[49] Philipp Kellmeyer. Big brain data: On the responsible use of brain data from clinical and consumer-directed neurotechnological devices. *Neuroethics*, 14:83–98, 2021. doi: 10.1007/s12152-018-9371-x.

[50] Tiziana Terranova. Free labor: Producing culture for the digital economy. *Social Text*, 18(2):33–58, 2000. doi: 10.1215/01642472-18-2_63-33.

[51] Christian Fuchs. *Digital Labour and Karl Marx*. Routledge, 2014.

[52] Michael Hardt. Affective labor. *Boundary 2*, 26(2):89–100, 1999.

[53] Anthony Dunne and Fiona Raby. *Speculative Everything: Design, Fiction, and Social Dreaming*. MIT Press, 2013.

[54] Jeffrey Bardzell and Shaowen Bardzell. What is 'critical' about critical design? In *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*, pages 3297–3306, 2013. doi: 10.1145/2470654.2466451.

[55] Langdon Winner. Do artifacts have politics? *Daedalus*, 109(1):121–136, 1980.

[56] Batya Friedman, Peter H. Kahn, and Alan Borning. Value sensitive design: Theory and methods. Technical Report 02-12, Department of Computer Science and Engineering, University of Washington, 2002.

[57] Alan R. Hevner, Salvatore T. March, Jinsoo Park, and Sudha Ram. Design science in information systems research. *MIS Quarterly*, 28(1): 75–105, 2004. doi: 10.2307/25148625.

[58] Paul Johannesson and Erik Perjons. *An Introduction to Design Science*. Springer, 2014. doi: 10.1007/978-3-319-10632-8.

[59] Robert K. Yin. *Case Study Research and Applications: Design and Methods*. SAGE Publications, 6th edition, 2018.

[60] Peter Checkland and Sue Holwell. Action research: Its nature and validity. *Systemic Practice and Action Research*, 11(1):9–21, 1998. doi: 10.1023/A:1022908820784.

[61] Talha Burak Alakus and Abdulhamit Subasi. GAMEEMO: A biometric EEG emotion recognition dataset. Mendeley Data, V3, 2020.

[62] Stamos Katsigiannis and Naeem Ramzan. DREAMER: A database for emotion recognition through EEG and ECG signals from wireless low-cost off-the-shelf devices. *IEEE Journal of Biomedical and Health Informatics*, 22(1):98–107, 2018. doi: 10.1109/JBHI.2017.2688239.

[63] Wei-Long Zheng, Jia-Yi Zhu, and Bao-Liang Lu. Identifying stable patterns over time for emotion recognition from EEG. *IEEE Transactions on Affective Computing*, 10(3):417–429, 2019. doi: 10.1109/TAFFC.2018.2832382.

[64] Mina Deng, Kim Wuyts, Riccardo Scandariato, Bart Preneel, and Wouter Joosen. A privacy threat analysis framework: Supporting the elicitation and fulfillment of privacy requirements. *Requirements Engineering*, 16(1):3–32, 2011. doi: 10.1007/s00766-010-0115-7.

[65] Reza Shokri, Marco Stronati, Congzheng Song, and Vitaly Shmatikov. Membership inference attacks against machine learning models. In *Proceedings of the 2017 IEEE Symposium on Security and Privacy*, pages 3–18, 2017.

[66] Matt Fredrikson, Somesh Jha, and Thomas Ristenpart. Model inversion attacks that exploit confidence information and basic countermeasures. In *Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security*, pages 1322–1333, 2015.

[67] Daniel J. Bernstein, Niels Duif, Tanja Lange, Peter Schwabe, and Bo-Yin Yang. High-speed high-security signatures. *Journal of Cryptographic Engineering*, 2(2):77–89, 2012.

[68] Simon Josefsson and Ilari Liusvaara. Edwards-Curve Digital Signature Algorithm (EdDSA). RFC 8032, Internet Engineering Task Force, 2017. URL https://www.rfc-editor.org/rfc/rfc8032.

[69] Chuan Guo, Tom Goldstein, Awni Hannun, and Laurens van der Maaten. Certified data removal from machine learning models. In *Proceedings of the 37th International Conference on Machine Learning*, pages 3832–3842. PMLR, 2020.

Appendix A: Complete CAAC Reference Policy Set

The following table lists all 15 rules in the reference CAAC policy set for a standard single-session artistic BCI installation, as specified in Section 5.4.3. In the main text, only representative rules are discussed in detail. This appendix provides the complete rule set for readers who wish to evaluate policy coverage or adapt the set for a different deployment context. Rules are listed in evaluation order; the first matching rule wins. The default effect (applied when no rule matches) is DENY. Wildcard (∗) matches any value; R15 implements the default-deny posture explicitly.

Table A.1: Complete CAAC reference policy set (15 rules). Rules are evaluated in order; first match wins. ALLOW = operation permitted; DENY = operation blocked and logged. MaxAgeDays is a configurable parameter (default 1 day per R12). Wildcard (∗) matches any requester or operation.

Rule	Requester	Operation	Feature Scope	Context	Effect	Rationale
R01	P5	read	mnfs_only	CT-bound	ALLOW	Aesthetic mapping reads MNFS-bound features
R02	P5	aggregate	mnfs_only	any	DENY	Aggregation not required for aesthetic mapping

continued on next page

Rule	Requester	Operation	Feature Scope	Context	Effect	Rationale
R03	P5	train	none	any	DENY	Model training outside declared scope
R04	P5	transfer	none	any	DENY	Data transfer outside declared scope
R05	P4	read	mnfs_only	CT-bound	ALLOW	Affective inference reads MNFS-bound features
R06	P4	aggregate	none	any	DENY	Aggregation not required for affective inference
R07	P6	read	none	any	DENY	Secondary backend outside declared scope
R08	P6	aggregate	none	any	DENY	Secondary backend not authorised
R09	P6	train	none	any	DENY	Model training outside declared scope
R10	P6	transfer	none	any	DENY	Data transfer not authorised under declared purpose
R11	RCP	delete	none	CT-bound	ALLOW	Revocation endpoint authorised to delete participant records

continued on next page

Rule	Requester	Operation	Feature Scope	Context	Effect	Rationale
R12	*	aggregate	mnfs_only	any	ALLOW (temporal: DENY if age > MaxAgeDays)	Temporal lock restricts aggregation to current-session features; MaxAgeDays is configurable (default 1 day)
R13	P5	write	none	any	DENY	P5 write isolation: P5 cannot persist data to any store
R14	P5	log	none	any	DENY	P5 log isolation: P5 cannot write directly to the audit log; all entries are produced exclusively by the PDC
R15	*	*	—	—	DENY	Default-deny catch-all; any requester-operation pair not explicitly permitted by R01–R14 is denied

The five policy fields—Requester, Operation, FeatureScope, Context, and MaxAgeDays—are generic parameters, not installation-specific values. For a different artistic BCI deployment, only the MNFS declaration and context token (CT) need to be redeclared; rules are then instantiated using the same logical structure. The FeatureScope field accepts any declared subset name (e.g., `theta_mnfs`, `alpha_mnfs`), allowing a single PDC to enforce differentiated access control over multiple feature subsets simultaneously.

The 15 rules above constitute one concrete instantiation; the policy language and default-deny posture are independent of these specific values.

Appendix B: Prototype Implementation Note

The Python proof-of-concept implementation of the Counter-Alchemy Framework comprises four core modules, one test suite and two experiment scripts. The modules are: `noc.py` (Neural Obfuscation Circuit, including `MNFSDeclaration`, band suppression, and Laplace noise injection (heuristic; see Section 6.5)); `ebh.py` (Experience-Binding Hash, including `compute_ebh`, `verify_ebh`, and `BoundFeatureRecord`); `caac.py` (Context-aware Access Control, including `PolicyRule` with `MaxAgeDays`, `PolicySet`, `AuditLog` with chain hashing, and `PolicyDecisionComponent`); and `sdm_p5.py` (SDM P5 Aesthetic Output Monitor, implementing `SDM_P5Monitor` and `compute_partial_correlation`).

The complete Tier 1 validation is self-contained in `tier1_validation.py`. It includes 38 automated test cases covering EBH security properties (7 checks), CAAC policy enforcement (22 checks), NOC functional correctness (3 checks), P5 write-isolation and SDM P5 output monitoring (3 checks), and MNFS boundary non-arbitrariness (3 checks, optionally using DREAMER data). All 38 tests pass on a standard Python 3.10+ environment with `numpy`, `scipy`, `scikit-learn`, and `cryptography` installed.

The experiment scripts comprise two files for Tier 2: `experiment_gameemo.py` (primary privacy-utility tradeoff on GAMEEMO G1 vs G3, 28 subjects, Emotiv EPOC); `experiment_seed4.py` (supplementary cross-session re-identification on SEED-IV, using alpha-band PSD features recomputed from raw EEG).

The complete code, including all module implementations, the Tier 1 validation test suite, and the experiment scripts, is available upon request from the author.

Appendix C: Threat Model Supplementary Material

C.1 EEKC Stage Descriptions

The following descriptions expand on Figure 4.2 in Chapter 4, detailing the threat mechanisms, empirical evidence, and STRIDE-E instances at each EEKC stage.

Stage 1: Prospecting

Prospecting describes the engineering of exploitation opportunities before neural data acquisition. Consent interfaces produce formally valid but substantively inadequate agreements: broadly worded clauses can authorise the full AEFS excess feature set and unrestricted P6 processing while providing nothing interpretable by non-specialists. The GDPR's specificity requirement (Article 7) offers limited protection because artistic BCI deployments rarely attract regulatory scrutiny. Institutional trust, experiential framing (data collection presented as co-authorship), and physical immersion collectively decouple formal consent validity from substantive informed consent. Stage 1 manifests S (identity spoofing via fabricated consent records) and E_2 (scope inflation via broadly worded consent) threats. The E_1 instance at this stage is structural: consent engineering that pre-authorises over-extraction constitutes the lifecycle entry point of experiential exploitation, distinguishing it from subsequent stages where E_1 operates on already-collected data.

Stage 2: Refining

Refining traces the transformation of raw EEG into structured feature representations at P2–P4, producing the AEFS without yet mapping features to semantic or commercial values. The primary exploitation mechanism

is over-extraction: retaining features whose dimensionality and semantic depth exceed the MNFS. In the running example ('Affective Currents', Section 6.4.1), the aesthetic purpose requires only a frontal theta arousal scalar, yet a standard Emotiv EPOC pipeline computes full PSD vectors across all bands, frontal alpha asymmetry, theta/alpha ratios, and spectral entropy. The excess features function as neural fingerprints (individual-specific alpha-band PSD signatures), enabling cross-session re-identification. Bidgoly et al. [36] demonstrate re-identification rates exceeding 90% within-session and 70% cross-session. The real-time feedback loop amplifies risk by increasing session duration and recording variety. STRIDE-E threats at Stage 2: Tampering (adversarial perturbation); Information Disclosure (re-identification via features); E_1 (over-extraction beyond MNFS); Repudiation (no logged extraction constraints).

Stage 3: Transmutation

Transmutation captures the semantic repurposing step where extracted representations are mapped onto aesthetic outputs (P5) and undisclosed data-asset value (P6). The key mechanism is the dual-use pipeline: an aesthetic function $M\colon F \to A$ is supplemented by a secondary valuation function $V\colon F \to L$ writing to DS3, invisible to participants. The artwork functions as an alibi: aesthetic output diverts scrutiny from the secondary valuation operation. STRIDE-E threats at Stage 3: Elevation of Privilege (P5 scope extension); Repudiation (no audit for V); E_1 (dual-use mapping). While Stage 4 focuses on longitudinal profiling, Stage 3 can enable single-session exploitation directly if transformation yields sufficiently high-fidelity features, removing the need for cross-session accumulation.

Stage 4: Valuation

Valuation models comparative assessment and pricing of neural data and derived models at P6 and DS3. Longitudinal profiling aggregates feature vectors across sessions. Model commodification operates via direct licensing and membership inference: Shokri et al. [65] showed models assign higher confidence to training inputs, enabling a third party to infer training-set membership. STRIDE-E threats at Stage 4: Information Disclosure (cross-session re-identification); Elevation of Privilege (model ownership); E_1 (affective labour extraction and commodification); Repudiation (no logs linking model parameters to sessions).

Stage 5: Circulation

Circulation articulates distribution of neural data, features, and derived models across the system boundary. The primary mechanism is decontextualization: severing data from the contextual constraints under which it was produced. Model inversion attacks [66] allow a third party with a licensed affect-recognition model to reconstruct approximate neural patterns. Archival accumulation creates a temporal exploitation risk that is a temporal analogue to harvest-now-decrypt-later: features collected under current limitations become sensitive as decoding improves. STRIDE-E threats at Stage 5: Information Disclosure; Repudiation (provenance loss); Tampering (retroactive re-analysis); E_1 (decontextualization and archival accumulation).

C.2 Data Flow Diagram: Component and Flow Specifications

Table C.1: Processing elements of a representative artistic BCI installation (see also Figure 4.1).

Component	**Role**	**Key Technical Detail**
P1 Signal Acquisition	Raw EEG input	128–512 Hz, 8–32 channels; hardware ADC
P2 Artifact Removal	Signal cleaning	Band-pass 0.5–50 Hz; ICA or threshold rejection
P3 Feature Extraction	Feature computation	PSD per band; alpha asymmetry; spectral entropy
P4 Affective Inference	Psychological estimation	Trained classifiers $\rightarrow$ valence, arousal, dominance
P5 Aesthetic Mapping	Artwork parameter generation	Inference $\rightarrow$ generative soundscape/visual output
P6 Secondary Processing	Backend operations	Aggregation, model training, transfers (CAAC-constrained)

Table C.2: Data flow enumeration for the artistic BCI installation DFD. E_1 = Experiential Exploitation; I = Information Disclosure; R = Repudiation; T = Tampering.

ID	From	To	Data Type	Boundary	Primary Threat
DF1	Participant	P1	Raw EEG ($C \times T$)	None	S: neural spoofing
DF2	P1	DS1/P2	Amplified EEG, 16/24-bit	None	T: adversarial perturbation
DF3	P2	P3	Cleaned EEG epochs	None	T: ICA suppression; E_1: over-retention
DF4	P3	DS2/P4	Feature vectors (PSD, asymmetry)	None	E_1: over-extraction; I: re-identification
DF5	P4	P5	Affective inference vector	None	E_1: dual-use mapping
DF6	DS2	P6	Stored feature vectors	Trust boundary	E_2: scope extension; E_1: aggregation
DF7	P6	DS3	Profiles, model weights	Trust boundary	R: provenance loss; E_1: commodification
DF8	DS3	Third Party	Derived models, metrics	System boundary	I: re-identification; E_1: decontextualisation

Appendix D: Framework Design Supplementary Material

D.1 RCP Operational Sequence

The following expands on the RCP description in Section 5.4. Upon a participant presenting their session token ST to the operator's revocation endpoint, the following four-step sequence is triggered:

1. **Identification:** the PDC queries DS2 and DS3 for all feature vector tuples whose session token hash matches the presented ST.
2. **Deletion:** the PDC issues a deletion command for all identified raw feature vectors and longitudinal profile entries.
3. **Unlearning (Phase 2):** if P6 has trained model components using features associated with the revoked ST, the framework may integrate a machine unlearning module. In the current proof-of-concept, this step is not yet implemented. Feature-level deletion (Phase 1) may not fully satisfy GDPR Article 17 where trained model weights constitute personal data; Phase 2 unlearning addresses this open problem.
4. **Certification:** the PDC records the revocation event and its completion in the append-only audit log, and produces a deletion certificate for the participant as evidence of compliance. This is an internal compliance artefact; it does not constitute a legal determination of GDPR Article 17 satisfaction.

D.2 EBH Implementation Details

The Ed25519 keypair (sk, pk) is generated fresh before each installation session. sk is retained privately by the operator; pk is published alongside CT via NMAP before session commencement, allowing any external auditor to verify EBH signatures without trusting the operator. Each feature vector is stored in DS2 as the tuple $(\hat{f}, \text{EBH}, CT, \tau)$ using the following encodings: EBH signature as a 64-byte hex string; CT as a JSON-serialised object including installation identifier, MNFS hash, and declaration timestamp; τ as ISO 8601 UTC. PD_hash is the SHA-256 hash of the human-readable purpose declaration string; CT is derived from the SHA-256 hash of the serialised MNFS declaration.

The declaration-binding property of the EBH assumes that the operator's public key *pk* is published through a channel that cannot be retroactively modified (e.g. a certificate transparency log, third-party notary service, or timestamped public repository). The current prototype implements *pk* publication via NMAP as an engineering simplification; it does not provide a decentralised or independently auditable trust anchor. Deployments requiring stronger non-repudiation guarantees should integrate *pk* publication into an append-only transparency infrastructure prior to session commencement.

D.3 NOC Frequency Band Parameters

In the running example (frontal theta MNFS, 4–8 Hz, channels AF3/F7/F3/F4/F8/AF4), the NOC suppresses the delta (0.5–4 Hz), alpha (8–13 Hz), beta (13–30 Hz), and gamma (30–50 Hz) bands using Butterworth band-rejection filters. The transition band introduces finite energy leakage at band edges; this is the source of the non-zero alpha-band residual noted in Section 6.5. The filter parameters are specified entirely by the MNFS declaration and are auditable via NMAP.

D.4 Threats to Individual Framework Components

Table D.1: Threats to individual Counter-Alchemy Framework components. HBC = honest-but-curious threat model.

Component	Threat	Mitigation	Residual Risk
MNFS Declaration	Operator over-declaration; undeclared code path in P3	SDM drift detection; NMAP audit publication	Sophisticated pipeline evasion exits HBC model
NOC	Hardware-level bypass of pre-NOC signals	Consumer headsets limit raw pre-amplification access	Risk not fully eliminated
Audit log	Root-level fabrication	Write-once storage; chain hashing	Requires hardware trust
CAAC	Pre-deployment policy manipulation	NMAP publication requirement	Governance, not technical control
Timestamp	Clock manipulation to circumvent MaxAgeDays	External time source assumption;[1] log monotonicity analysis	Detectable, not prevented
P5 intra-process	Hidden computation using legitimately-read MNFS features[2]	R13/R14 block storage pathway; SDM-P5 detects output encoding	Detection threshold calibration pending real installation data

[1] The timestamp integrity assumption presupposes an externally auditable time source (e.g., a network-synchronised clock or NTP server whose outputs are logged at session initialisation). In deployments where such a source is unavailable, the MaxAgeDays constraint in R12 functions as a non-adversarial compliance record rather than a tamper-resistant temporal bound.

[2] The intra-process computation gap denotes the following: a P5 component granted READ access to MNFS features may perform arbitrary internal computations (e.g., hidden encoding of session time) without invoking WRITE or LOG operations, rendering CAAC enforcement ineffective; SDM-P5 output monitoring provides the only available detection pathway.

D.5 Graceful Degradation Under Partial Deployment

Table D.2: Graceful degradation under partial deployment.

Layer fails	**Impact**	**Residual Protection**
Layer 1	Excess features in DS2 potentially exposed if CAAC policies are permissive	Layer 2 CAAC; Layer 3 governance
Layer 2	No cryptographic context binding or access control on DS2	Layer 1 MNFS enforcement at source
Layer 3	Governance, revocation, and accountability functions lost	Layer 1 and Layer 2 full protection

D.6 Counter-Alchemy Framework Threat Coverage

Table D.3: Counter-Alchemy Framework threat coverage. S1–S5 = EEKC Stages.

Mechanism	**STRIDE-E / EEKC**	**Key Technical Property**
MNFS Declaration	E_1 (S2); E_2 (S2); R (S2)	Formally specifies AEFS/MNFS boundary; reference for NOC and SDM

Mechanism	STRIDE-E/EEKC	Key Technical Property
Neural Obfuscation Circuit	E_1 (S2); I (S2); T (S2)	Band-selective suppression enforces MNFS; Laplace noise reduces re-identification
Experience-Binding Hash	R (S2–S4); T (S3–S5); E_1 (S3–S4)	Ed25519 binding to CT and PD; tamper evidence and declaration binding
Context-aware Access Control	E_1 (S3–S4); E_2 (S3–S4); R (S3–S4); I (S4)	Operation-level policy; append-only audit log
Reverse-Clearance Protocol	E_1 (S5); R (S4–S5); I (S5)	Session token $\rightarrow$ deletion certificate (Phase 1); unlearning (Phase 2) future
Non-Monetary Accountability Protocol	E_1 (S1, S5); R (S1–S5)	NDUR transparency; cultural credit; independent audit
Semantic Drift Monitor	E_1 (S2–S3); E_2 (S2); R (S2–S3)	Statistical DS2 monitoring; P5 output correlation detection

D.7 Notes on Real-Time Pipeline Latency

The Counter-Alchemy Framework introduces four latency-contributing components: the NOC filter, CAAC policy decision, audit log append, and SDM sampling. Their contributions to the real-time pipeline differ substantially.

The NOC Butterworth filter adds approximately 10–20 ms group delay (Section 6.5), representing the dominant latency contribution. This falls within the typical 100–500 ms real-time BCI latency budget and is unlikely to be perceptible to participants.

The remaining three components are not on the critical real-time path. CAAC policy decision is $O(\text{number of rules})$ and is estimated at under 0.1 ms in the Python prototype; EBH signing and verification average 27.15 μs per call (Section 6.2). Audit log append is a sequential write operation, typically under 1 ms. The SDM runs at configurable sampling intervals rather than on every signal packet (Section 5.5), and therefore does not introduce per-packet latency.

In a production deployment, CAAC decisions, audit logging, and SDM sampling can be executed in parallel threads or as post-processing operations, decoupled from the P1→P5 signal-to-output path. The real-time constraint applies only to the signal acquisition-to-aesthetic-output pipeline; governance and monitoring operations do not need to block this path.

End-to-end cumulative latency under live streaming conditions has not been empirically measured; this remains an open empirical question requiring future live prototyping to confirm.

Appendix E: Validation Supplementary Material

E.1 Tier 3 Scenario Walkthrough: Stage-by-Stage Detail

The following expands on Table 6.3 in Chapter 6, providing the full without/with-framework narrative for each EEKC stage in the 'Affective Currents' scenario.

Stage 1 (Prospecting): Consent Engineering Interruption

Without the framework: the operator's consent form uses the clause 'your neural data may be used for research, development, and product improvement purposes', authorising training affect-recognition models and selling engagement analytics. Participants sign without substantive understanding of these secondary uses.

With the framework: the NMAP requires an MNFS declaration formally specifying that only frontal theta power is required. This declaration must be reflected in the consent form in accessible language: 'We capture only the strength of slow brain activity in your forehead area (4–8 Hz), which we use to adjust the soundscape in real time.' The MNFS declaration is hashed to produce CT, embedded in all EBH computations. Each participant receives a session token (QR code on a paper receipt) providing access to the RCP.

Stage 2 (Refining): Over-Extraction Interruption

Without the framework: the default Emotiv EPOC software computes full PSD features across all 14 channels and five frequency bands, producing a

70-dimensional feature vector including alpha-band fingerprinting signatures and spectral entropy measures with health-relevant correlates.

With the framework: the NOC intercepts the signal at P2 output, applying band-rejection filters to all bands outside the MNFS theta specification. The 14-channel signal is further restricted to six frontal channels. Laplace noise is injected at $\varepsilon = 1.0$. The resulting 6-dimensional feature vector is bound with the EBH and stored in DS2 as a BoundFeatureRecord tuple.

Stage 3 (Transmutation): Dual-Use Mapping Interruption

Without the framework: P5 and P6 share DS2 access. When P5 reads a feature vector for the soundscape, P6 simultaneously computes a valuation score $V = w_1 \times |\hat{f}| + w_2 \times$ session_duration $+ w_3 \times$ arousal_confidence, writes to DS3, and adds the participant's record to a longitudinal engagement model.

With the framework: the CAAC PDC intercepts P6's attempted DS2 read and matches Rule R07 (DENY: P6, READ, any). The audit log records the denial: `AE-000006: P6, read, DENIED, rule=R07, session_token_hash=a3f8....` P5's read request is separately permitted under R01. The dual-use valuation operation does not occur.

Stage 4 (Valuation): Longitudinal Profiling Interruption

Without the framework: after two weeks, DS3 contains longitudinal feature vectors for approximately 700 participants. P6 aggregates these into per-participant engagement profiles, computes valuation rankings, and prepares training data for an affect-recognition model.

With the framework: P6's AGGREGATE and TRAIN requests are blocked by Rules R08 and R09, both logged. The SDM's statistical monitoring detected no MNFS drift across the two-week run. The NDUR documents zero secondary processing attempts and 14 CAAC policy denials.

Stage 5 (Circulation): Decontextualisation Interruption

Without the framework: the operator transfers DS3 contents to a brand analytics partner under an undisclosed data processing agreement.

With the framework: P6's TRANSFER request is blocked by Rule R10 and logged. Two multi-session participants exercise revocation rights: the RCP validates each token against the audit log, removes the associated feature vectors from DS2, issues a timestamped deletion certificate, and flags the sessions as revoked. The deletion attestation covers registered storage

systems; unregistered secondary copies fall outside the framework's governance scope.

E.2 LOSO Reanalysis: Methodological Note

The Leave-One-Subject-Out (LOSO) reanalysis compares two conditions in a paired design: the AEFS baseline (70-dimensional full feature set) and the band-suppression condition (6-dimensional frontal theta features via NOC with $\varepsilon = \infty$). For each held-out subject, a classifier (SVM, RBF kernel, $C = 1$, `gamma=scale`) was trained on all epochs from the remaining 27 subjects and evaluated on all epochs of the held-out subject using balanced accuracy, yielding one accuracy value per condition per subject. The paired t-test and Cohen's d are computed over the 28 per-subject difference scores ($d = \bar{x}_{\text{diff}}/s_{\text{diff}}$, paired-sample formulation). Results: LOSO band-suppression 0.546 ± 0.115; $t(27) = 5.54$, $p < 0.001$, Cohen's $d = 1.05$; vs. chance: $t(27) = 2.10$, $p = 0.046$.